

WEB APPLICATION PENETRATION TESTING ASSESSMENT

OWASP Juice Shop

Portfolio Edition | Authorized Local Docker Lab

Prepared by	Obadah Loul
Assessment Period	May 2026
Target	OWASP Juice Shop
Environment	Docker / localhost
Assessment Type	Web Application Penetration Test

Ethical Testing Notice

All testing documented in this report was performed against a locally hosted, intentionally vulnerable OWASP Juice Shop instance. No external, public, or third-party systems were scanned or exploited.

Evidence Privacy Note: Personal identifiers and unrelated local metadata visible in original screenshots have been covered with black redaction boxes. Technical evidence and security-relevant content were left unchanged.

Contents

1. Executive Summary
 2. Scope and Rules of Engagement
 3. Methodology
 4. Environment Verification
 5. Reconnaissance and Technology Fingerprinting
 6. Scanning and Enumeration
 7. Vulnerability Assessment and Prioritization
 8. Detailed Findings
 9. Additional Validation Evidence
 10. Post-Exploitation Impact and Attack Chain
 11. Detection and Log Analysis
 12. Remediation Plan
 13. Retest Criteria and Conclusion
- Appendix A. Supporting Evidence
- Appendix B. Evidence Coverage Index
- Appendix C. Extended Evidence Gallery
- Appendix D. References

1. Executive Summary

A structured penetration test was performed against a locally deployed OWASP Juice Shop instance. The goal was to approach the application as an attacker would: first understand the technology stack and exposed attack surface, then validate exploitable weaknesses, assess their impact, and finish with concrete remediation and detection recommendations.

The assessment identified weaknesses in authentication, authorization, browser-side input handling, public file exposure, diagnostic endpoints, and error handling. The highest-impact issue was SQL injection in the login workflow, which enabled authentication bypass and an administrator session. Once privileged access was obtained, the administrative interface exposed registered-user and customer-feedback functionality. Independent weaknesses also exposed internal files, backup metadata, runtime metrics, and detailed server errors.

Category	Assessment
Overall Risk Level	CRITICAL
Critical Findings	2
High Findings	4
Medium Findings	2
Testing Model	Manual validation in a local Docker lab
Primary Standards	OWASP Top 10 (2021), CVSS-based prioritization

1.1 Key Security Impacts

- Authentication bypass allowed an administrator session without valid credentials.
- Privileged application functionality became reachable after authentication bypass.
- Publicly accessible files exposed internal documents and developer artifacts.
- DOM-based XSS allowed attacker-controlled markup to execute in the browser context.
- An unauthenticated metrics endpoint exposed runtime and operational information.
- Verbose error handling disclosed stack traces, internal paths, and framework details.
- Encoded file-path input enabled retrieval of backup package metadata.

1.2 Highest-Priority Actions

- Replace unsafe SQL construction with parameterized queries or ORM-managed statements.
- Enforce authorization on the server for every privileged API and administrative action.
- Remove public backup files and sensitive documents from web-accessible directories.
- Encode untrusted output, avoid unsafe HTML rendering, and use a restrictive Content Security Policy.
- Protect monitoring endpoints and suppress detailed production error messages.
- Centralize application logs and alert on injection patterns, null-byte requests, repeated HTTP 500 responses, and unusual privileged access.

2. Scope and Rules of Engagement

Parameter	Value
Target Application	OWASP Juice Shop
Primary URL	http://localhost:3000
Alternate URL	http://127.0.0.1:3000
Deployment	Official OWASP Juice Shop Docker image
Network Exposure	Loopback interface only
Assessment Period	May 2026

2.1 In Scope

- Application pages, routes, APIs, and browser-accessible assets in the local Juice Shop instance.
- HTTP response headers, error messages, diagnostic endpoints, and client-side JavaScript.
- The /ftp directory, /api/* routes, /rest/* routes, and robots.txt.
- Controlled validation of identified web application vulnerabilities.
- Application and Docker logs generated by the local lab during testing.

2.2 Out of Scope

- Public Juice Shop demo instances or cloud-hosted copies.
- Any third-party or unrelated systems.
- Denial-of-service or destructive testing.
- Host operating-system exploitation, persistence, or destructive post-exploitation.
- Use of real personal data, production credentials, or live tokens.

2.3 Tools and Evidence Sources

- Docker CLI
- Nmap / Zenmap
- Chrome Developer Tools - Network, Sources, Console, and Application views
- Manual HTTP request and response analysis
- Google search / passive OSINT
- NVD, MITRE CVE, and GitHub Security Advisories
- OWASP Juice Shop documentation and companion material

2.4 Evidence Handling

Screenshots were retained where they demonstrate a meaningful testing step, technical observation, or exploit result. For the public portfolio edition, personal identifiers and unrelated metadata were redacted with black boxes. The redactions do not change the security-relevant portions of the screenshots.

3. Methodology

The assessment followed a seven-stage workflow. Each stage used the results of the previous stage to narrow the attack surface and prioritize the next test. Manual validation was used to confirm findings and avoid treating reconnaissance or advisory research as proof of exploitability.

Stage	Activity
1. Environment Verification	Deploy the local target, confirm loopback-only exposure, and establish a baseline.
2. Reconnaissance	Collect passive information about the application, architecture, documentation, and known security issues.
3. Scanning & Enumeration	Confirm open services, inspect headers, enumerate routes, files, and client-side assets.
4. Vulnerability Assessment	Map candidate issues to OWASP Top 10 categories and prioritize using CVSS-based risk.
5. Exploitation	Validate selected issues with controlled proof-of-concept testing.
6. Impact & Detection	Review resulting access, exposed data, logs, and defender-visible observables.
7. Reporting & Remediation	Document root causes, security impact, remediation guidance, and retest criteria.

3.1 Validation Principles

- A finding was treated as confirmed only after the behavior was reproduced in the local target.
- CVE and advisory research was used for context and patching awareness, not as automatic proof of vulnerability.
- Testing remained inside the localhost lab boundary.
- Evidence was collected at each major phase to make the workflow reproducible and reviewable.

4. Environment Verification

4.1 Local Docker Deployment

OWASP Juice Shop was deployed from the official Docker image and bound to 127.0.0.1:3000. Restricting the service to the loopback interface kept the assessment environment isolated from external networks.

```
docker pull bkimminich/juice-shop
docker run -d -p 127.0.0.1:3000:3000 bkimminich/juice-shop
docker ps
```

```

docker --version
Docker version 29.3.1, build c2be9cc

docker pull bkimminich/juice-shop
Using default tag: latest
latest: Pulling from bkimminich/juice-shop
Digest: sha256:a8139c141311c7f31fcf2e611125246928f703ee42827de33983fd9425d1b2f6
Status: Image is up to date for bkimminich/juice-shop:latest
docker.io/bkimminich/juice-shop:latest

docker run -d --name [REDACTED] -p 127.0.0.1:3000:3000 bkimminich/juice-shop
docker: Error response from daemon: Conflict. The container name "[REDACTED]" is already in use by container "[REDACTED]". You have to remove (or rename) that container to be able to reuse that name.

Run 'docker run --help' for more information

docker ps
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS                               NAMES
0810f293262b  bkimminich/juice-shop  "/nodejs/bin/node /j..."  8 minutes ago  Up 8 minutes  127.0.0.1:3000->3000/tcp          [REDACTED]

date
The current date is: 09/05/2026
Enter the new date: (dd-mm-yy)
[REDACTED]
```

Figure 1 - Docker image retrieval, container execution, loopback port binding, and container status. Privacy-sensitive identifiers have been redacted.

4.2 Baseline Application State

Before exploitation, the Juice Shop scoreboard was reviewed to establish the initial challenge state. This provided a baseline that could later be compared with confirmed test results.

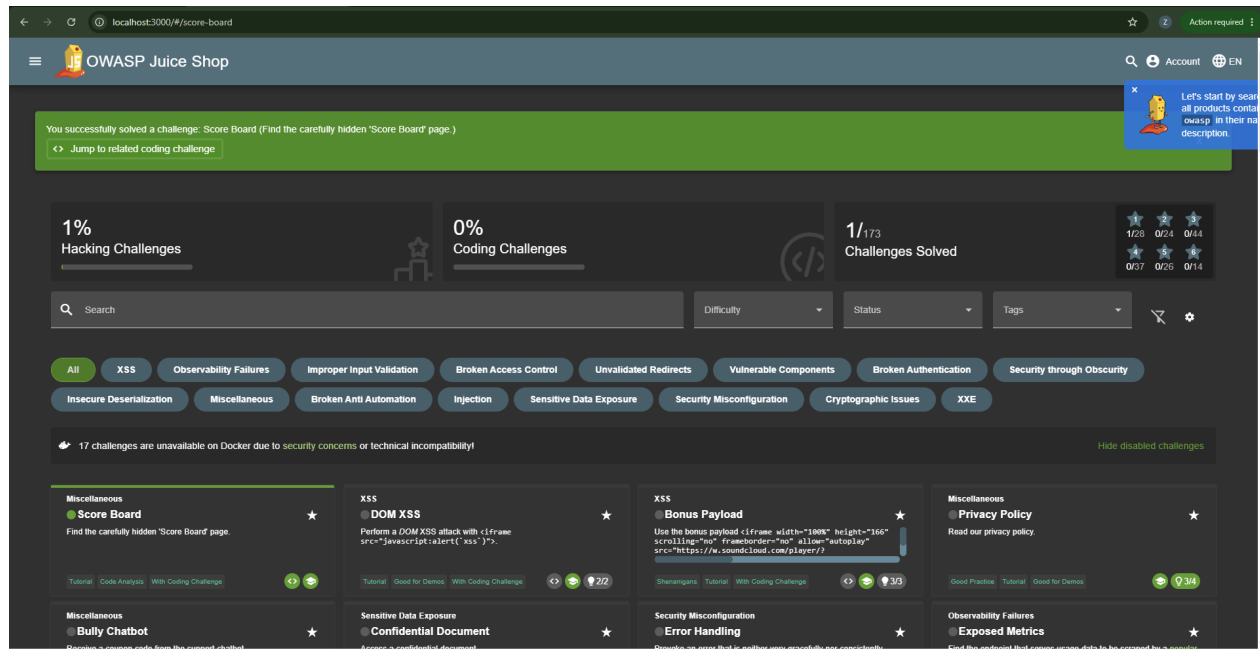


Figure 2 - Full baseline Juice Shop scoreboard before the main exploitation sequence.

5. Reconnaissance and Technology Fingerprinting

5.1 Passive OSINT

Passive reconnaissance focused on official project material, the Juice Shop companion guide, public repository metadata, and challenge documentation. Four targeted searches were used to understand the application architecture and identify useful sources before interacting more deeply with the local application.

Query	Purpose
site:owasp.org "juice shop"	Locate the official OWASP project and architecture information.
intitle:"pwning owasp juice shop"	Locate the official companion guide and challenge documentation.
site:github.com bkimminich/juice-shop filetype:json "dependencies"	Review public dependency metadata and likely framework versions.
inurl:juice-shop CTF "challenge"	Identify challenge categories and attack-surface themes for prioritization.

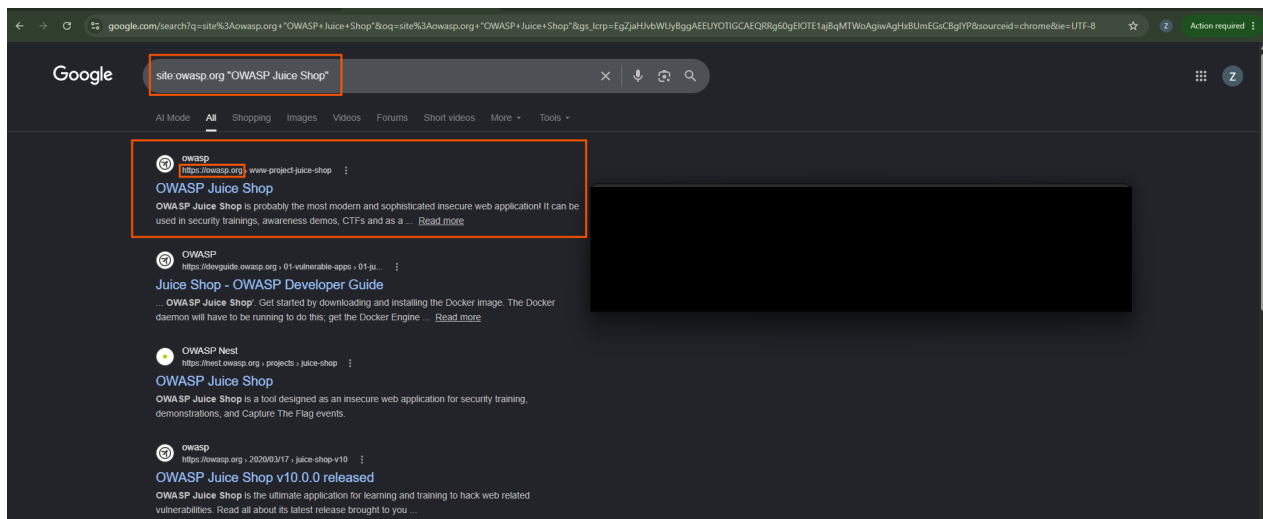


Figure 3a - Full passive-reconnaissance evidence used to locate the official OWASP Juice Shop project. The unrelated evidence terminal is precisely redacted.

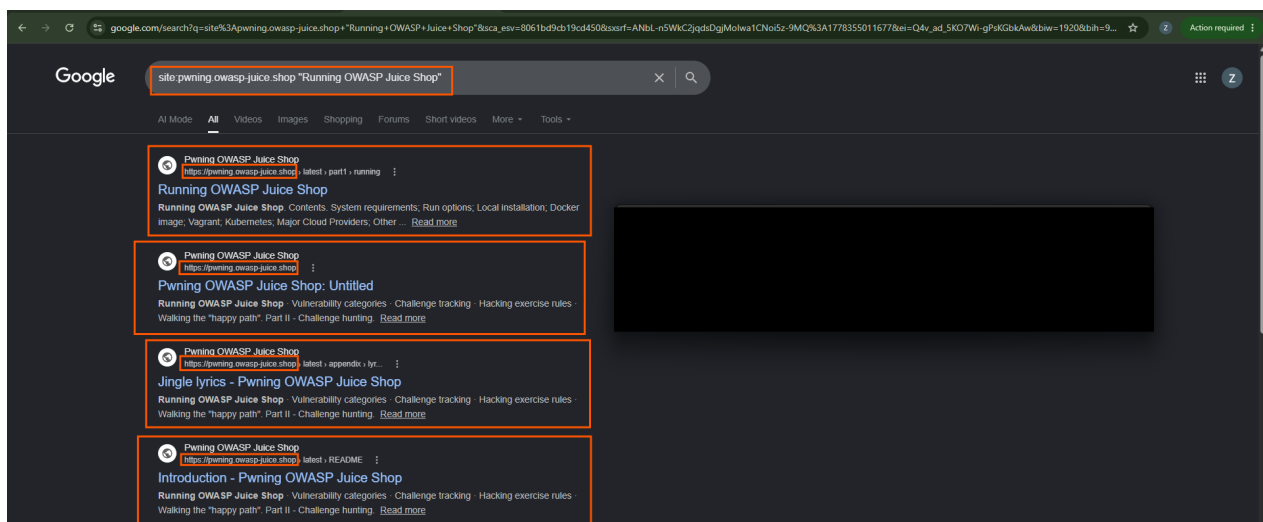


Figure 3b - Full passive-reconnaissance evidence used to locate the official Juice Shop companion guide. The unrelated evidence terminal is precisely redacted.

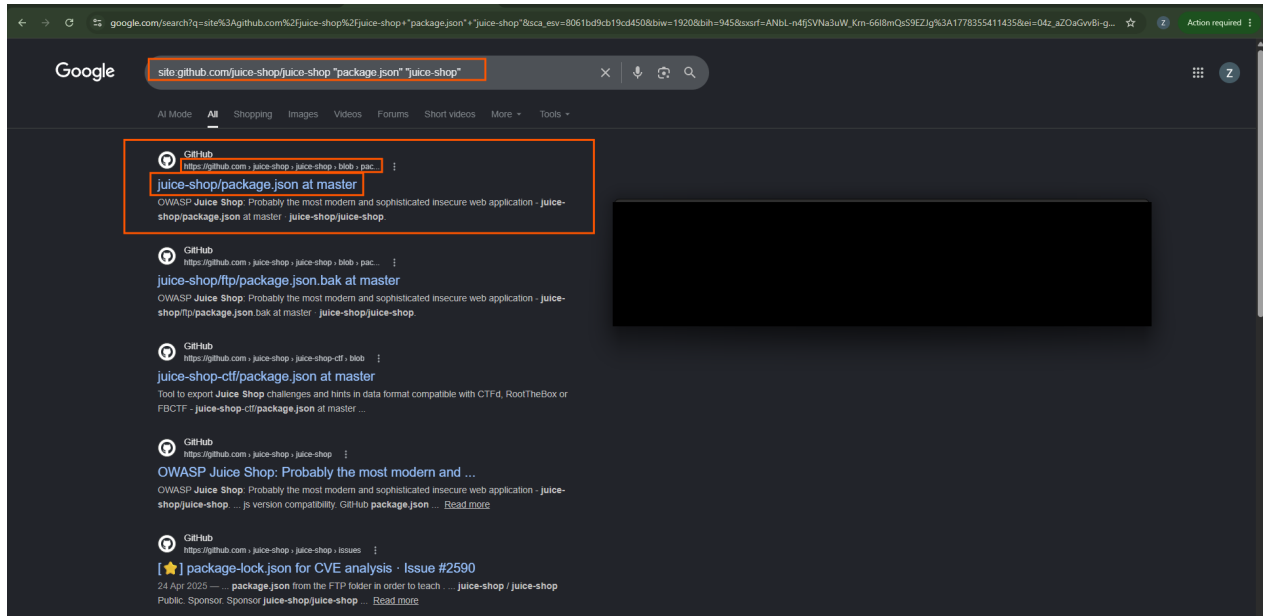


Figure 4a - Full public-repository search evidence used to locate package metadata relevant to technology fingerprinting.

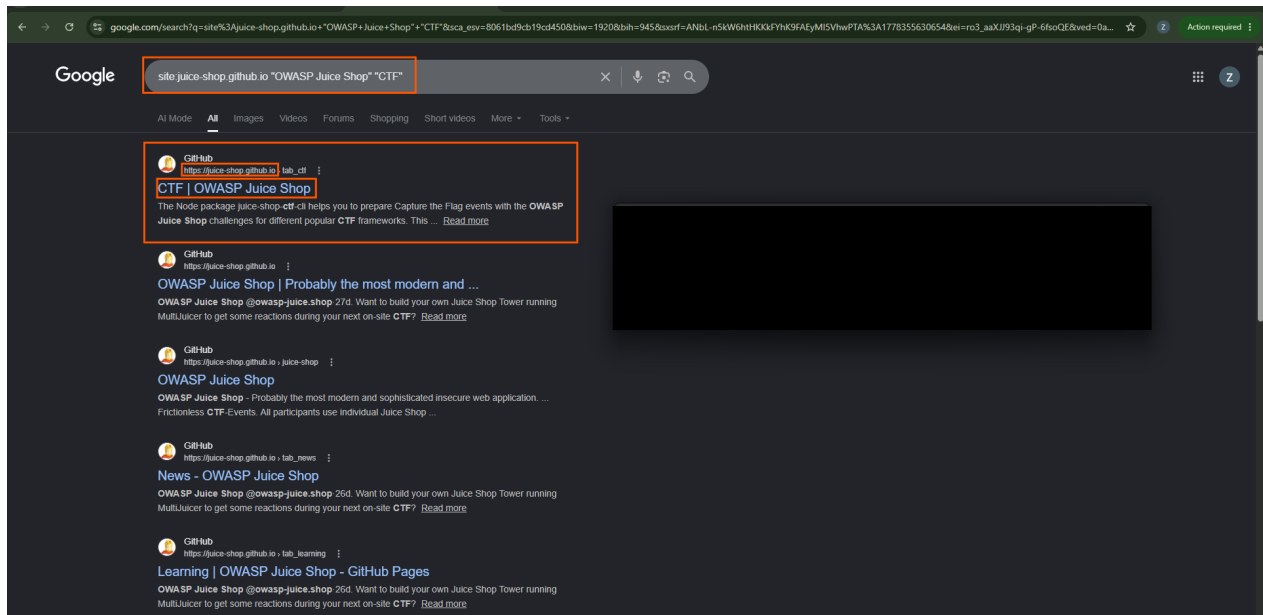


Figure 4b - Full challenge/CTF documentation search evidence used during attack-surface prioritization.

The reconnaissance phase confirmed that the application uses Node.js, Express, Angular, and SQLite-related components. It also highlighted recurring security themes that were later validated manually, including injection, cross-site scripting, access-control weaknesses, and exposed files.

5.2 HTTP and Browser-Based Fingerprinting

Technology fingerprinting combined multiple sources rather than relying on a single header or page. HTTP responses, browser developer tools, application assets, public package metadata, and server error behavior were compared to identify the application stack.

```

curl -I http://localhost:3000
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Sat, 09 May 2026 15:02:12 GMT
ETag: W/"124fa-19e0d42a6b1"
Content-Type: text/html; charset=UTF-8
Content-Length: 75002
Vary: Accept-Encoding
Date: Sat, 09 May 2026 19:45:52 GMT
Connection: keep-alive
Keep-Alive: timeout=5

echo DateTime: %date%
DateTime: 09/05/2026

```

Figure 5a - Full command-line HTTP response-header evidence used during technology fingerprinting. Personal and session-specific identifiers are precisely redacted while the HTTP response remains intact.

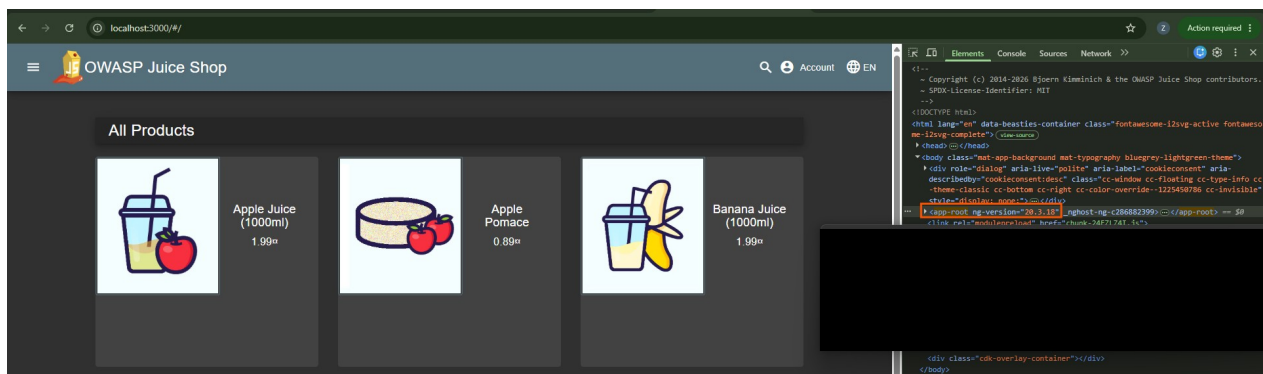


Figure 5b - Full browser/developer-tools fingerprinting evidence showing the application and Angular runtime context.

Technology	Approx. Version	Identification Method
Node.js	18.x / 20.x	HTTP behavior, package metadata, and server-error context.
Express.js	4.18.x	X-Powered-By header, dependency metadata, and route behavior.
Angular	15.x	Browser assets, application bundles, and Angular-related package metadata.
SQLite / better-sqlite3	5.x	Dependency metadata and database-related error context.

5.3 Dependency Metadata Review

Public package metadata was used to cross-check the observed stack and to understand which libraries would be relevant during advisory research. This step supported technology identification; it was not treated as a finding by itself. The evidence below is split across two figures so individual package details remain readable.

```

juice-shop / package.json
Code Blame 283 lines (283 loc) · 8.26 KB
254   "socket.io-client": "^3.1.3",
255   "source-map-support": "^0.5.21",
256   "ts-jest": "^29.2.5",
257   "ts-node": "^10.9.2",
258   "typescript": "~5.3.3"
259 },
260 "engines": {
261   "node": "20 - 24"
262 },
263 "os": [
264   "win32",
265   "linux",
266   "darwin",
267   "freebsd",
268   "openbsd"
269 ],
270 "cpu": [
271   "x64",
272   "x32",
273   "arm64",
274   "arm"
275 ],
276 "heroku-run-build-script": true,
277 "standard": {
278   "global": [
279     "angular",
280     "inject"
281   ]
282 }
283 }
  
```

Figure 6a - Full public package metadata showing Node.js engine requirements.

```

juice-shop / package.json
Code Blame 283 lines (283 loc) · 8.26 KB
114   "lcov",
115   "text-summary"
116 ]
117 },
118 "dependencies": {
119   "@fontsource/roboto": "^5.2.9",
120   "body-parser": "^1.20.4",
121   "check-dependencies": "^1.1.1",
122   "check-internet-connected": "^2.0.6",
123   "clarinet": "^0.12.6",
124   "colors": "1.4.0",
125   "compression": "1.8.1",
126   "config": "3.3.12",
127   "cookie-parser": "1.4.7",
128   "cookieconsent": "3.1.1",
129   "cors": "2.8.5",
130   "download": "8.0.0",
131   "errorhandler": "1.5.1",
132   "ethers": "6.16.0",
133   "express": "4.22.1",
134   "express-ipfilter": "1.3.2",
135   "express-jwt": "0.1.3",
136   "express-rate-limit": "7.5.1",
137   "express-robots-txt": "0.5.1",
138   "express-security-txt": "2.1.1",
139   "feature-policy": "0.6.0",
140   "file-stream-rotator": "1.0.0",
141   "file-type": "16.5.4",
142   "finale-rest": "1.2.2",
143   "fs-extra": "9.1.0",
  
```

Figure 6b - Full dependency metadata showing Express-related package information.

```

juice-shop / package.json
Code Blame 283 lines (283 loc) · 8.26 KB
247 "frisby": "github:bkimminich/frisby",
248 "grunt-cli": "^1.5.0",
249 "jest": "^29.7.0",
250 "mocha": "^8.4.0",
251 "nyc": "^15.1.0",
252 "sinon": "^11.1.2",
253 "sinon-chai": "^3.7.0",
254 "socket.io-client": "^3.1.3",
255 "source-map-support": "^0.5.21",
256 "ts-jest": "^29.2.5",
257 "ts-node": "^10.9.2",
258 "typescript": "~5.3.3"
259 },
260 "engines": {
261   "node": "20 - 24"
262 },
263 "os": [
264   "win32",
265   "linux",
266   "darwin",
267   "freebsd",
268   "openbsd"
269 ],
270 "cpu": [
271   "x64",
272   "x32",

```

heroku-run-build-script

1 Reference Search

In this file

276 "heroku-run-build-script": true,

Search for this symbol

Figure 6c - Full package metadata used to cross-check additional runtime requirements.

```

juice-shop / ftp / package.json.bak
Code Blame 177 lines (177 loc) · 4.19 KB
60 "html-entities": "^1.2",
61 "jasmine": "^2.8.0",
62 "js-yaml": "3.10",
63 "jsonwebtoken": "~8",
64 "jssha": "~2.3",
65 "libxmljs": "~0.18",
66 "marsdb": "~0.6",
67 "morgan": "~1.9",
68 "multer": "~1.3",
69 "pdfkit": "~0.8",
70 "replace": "~0.3",
71 "request": "~2",
72 "sanitize-html": "1.4.2",
73 "sequelize": "~4",
74 "serve-favicon": "~2.4",
75 "serve-index": "~1.9",
76 "socket.io": "~2.0",
77 "sqlite3": "~3.1.13",
78 "z85": "~0.0"
79 },
80 "devDependencies": {
81   "chai": "~4",
82   "codeclimate-test-reporter": "~0.5.1",
83   "cross-spawn": "~5.1",
84   "eslint": "~4.7",
85   "eslint-scope": "3.7.2",
86   "form-data": "~2.3",
87   "frisby": "~2.0",

```

heroku-run-build-script

1 Reference Search

In this file

276 "heroku-run-build-script": true,

Search for this symbol

Figure 6d - Full SQLite-related dependency metadata used to validate the observed database stack.

5.4 Known-Vulnerability Research

Known vulnerabilities affecting identified technologies were reviewed using NVD, MITRE CVE, and GitHub Security Advisories. The purpose was to understand patching context and known security history. Advisory presence alone was not treated as proof that the local application was exploitable. For example, the SQL injection validated later was caused by application-level query construction rather than a SQLite CVE.

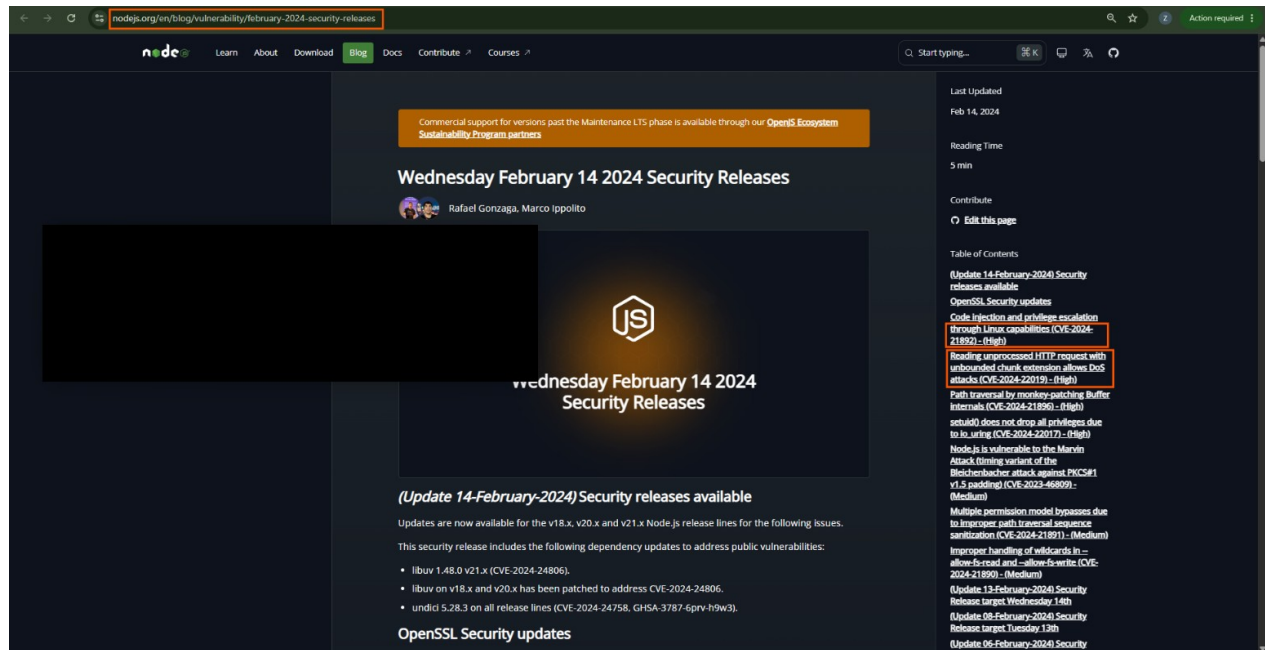


Figure 7a - Full Node.js security-advisory research used for patching context.

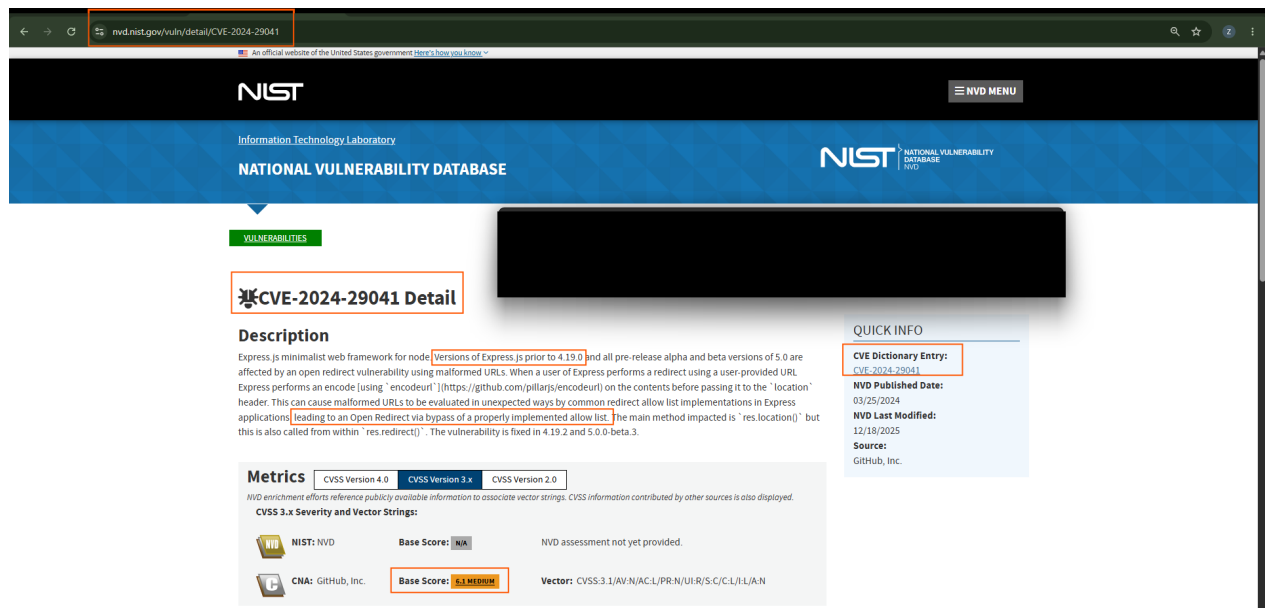


Figure 7b - Full NVD evidence for an Express-related advisory reviewed during research.

GitHub Advisory Database / GitHub Reviewed **CVE-2024-43796**

express vulnerable to XSS via response.redirect()

(Low severity) (GitHub Reviewed) Published on Sep 10, 2024 in expressjs/express • Updated on Nov 18, 2024

Vulnerability details Dependabot alerts 0

Package	Affected versions	Patched versions
express (npm)	< 4.20.0	4.20.0
	>= 5.0.0-alpha.1, < 5.0.0	5.0.0

Description

Impact

In express <4.20.0, passing untrusted user input - even after sanitizing it - to response.redirect() may execute untrusted code

Patches

this issue is patched in express 4.20.0

Workarounds

users are encouraged to upgrade to the patched version of express, but otherwise can workaround this issue by making sure any untrusted inputs are safe, ideally by validating them against an explicit allowlist

Details

successful exploitation of this vector requires the following:

- The attacker MUST control the input to response.redirect()
- express MUST NOT redirect before the template appears

CVSS v4 base metrics

Exploitability Metrics

Metric	Score
Attack Vector	Network
Attack Complexity	Low
Attack Requirements	Present
Privileges Required	None
User Interaction	Passive

Vulnerable System Impact Metrics

Metric	Score
Confidentiality	None
Integrity	None
Availability	None

Subsequent System Impact Metrics

Metric	Score
Confidentiality	Low
Integrity	Low
Availability	Low

Learn more about base metrics

CVSS:4.0/AV:N/AC:L/AT:P/PR:N/URP:NCN/VEN:WAN/S:CL/SH:SA:L

Figure 7c - Full GitHub advisory evidence for an Express-related vulnerability.

GitHub Advisory Database / GitHub Reviewed **CVE-2024-21490**

angular vulnerable to super-linear runtime due to backtracking

(High severity) (GitHub Reviewed) Published on Feb 10, 2024 to the GitHub Advisory Database • Updated on Nov 4, 2025

Vulnerability details Dependabot alerts 0

Package	Affected versions	Patched versions
angular (npm)	>= 1.3.0, <= 1.8.3	None
org.webjars.bower:angular (Maven)	>= 1.3.0, <= 1.8.3	None
org.webjars.npm:angular (Maven)	>= 1.3.0, <= 1.8.3	None

Description

This affects versions of the package angular from 1.3.0. A regular expression used to split the value of the ng-srcset directive is vulnerable to super-linear runtime due to backtracking. With a large carefully-crafted input, this can result in catastrophic backtracking and cause a denial of service.

Note:

This package is EOL and will not receive any updates to address this issue. Users should migrate to @angular/core.

References

- <https://nvd.nist.gov/vuln/detail/CVE-2024-21490>
- <https://security.snyk.io/vuln/SNYK-JS-ANGULAR-6091113>
- <https://stackblitz.com/edit/angularjs-vulnerability-ng-srcset-redos>
- <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-6241746>
- <https://security.snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-6241747>
- <https://support.hiero-devs.com/hc/en-us/articles/25715686953485-CVE-2024-21490-AngularJS-Regular-Expression-Denial-of-Service-RedoS>
- <https://lists.debian.org/debian-its-announce/2025/07/msg00005.html>

CVSS v3 base metrics

Attack vector

Metric	Score
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

Learn more about base metrics

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/SU:C/N/A/H

EPSS score

2.246% (85th percentile)

Weaknesses

► CWE-1333

CVE ID

CVE-2024-21490

GHSA ID

Figure 7d - Full Angular advisory research used to review client-side framework risk.

NIST Information Technology Laboratory
NATIONAL VULNERABILITY DATABASE

VULNERABILITIES

CVE-2024-0232 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

A heap use-after-free issue has been identified in SQLite in the jsonParseAddNodeArray() function in sqlite3.c. This flaw allows a local attacker to leverage a victim to pass specially crafted malicious input to the application, potentially causing a crash and leading to a denial of service.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

Source	Base Score	Vector
NIST: NVD	5.5 MEDIUM	CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
CNA: Red Hat, Inc.	5.7 MEDIUM	CVSS:3.1/AV:L/AC:H/PR:N/UI:R/S:U/C:N/I:N/A:H

QUICK INFO

CVE Dictionary Entry:
CVE-2024-0232

NVD Published Date:
01/16/2024

NVD Last Modified:
11/21/2024

Source:
Red Hat, Inc.

Figure 7e - Full NVD evidence for a SQLite-related advisory reviewed for context.

NIST Information Technology Laboratory
NATIONAL VULNERABILITY DATABASE

VULNERABILITIES

CVE-2023-7104 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

A vulnerability was found in SQLite (SQLite3) up to 3.43.0 and classified as critical. This issue affects the function sessionReadRecord of the file ext/session/sqlite3session.c of the component make alltest Handler. The manipulation leads to heap-based buffer overflow. It is recommended to apply a patch to fix this issue. The associated identifier of this vulnerability is VDB-248999.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

Source	Base Score	Vector
NIST: NVD	7.3 HIGH	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
CNA: VulDB	5.5 MEDIUM	CVSS:3.1/AV:A/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

QUICK INFO

CVE Dictionary Entry:
CVE-2023-7104

NVD Published Date:
12/29/2023

NVD Last Modified:
11/03/2025

Source:
VulDB

Figure 7f - Additional full SQLite advisory evidence used for cross-checking.

6. Scanning and Enumeration

6.1 Port and Service Scan

Nmap was run only against the loopback address to confirm the service exposed by the local target. TCP port 3000 was open and served the Juice Shop web application. No additional target service ports were identified in the tested local configuration.

`nmap -sV -p 3000 127.0.0.1`

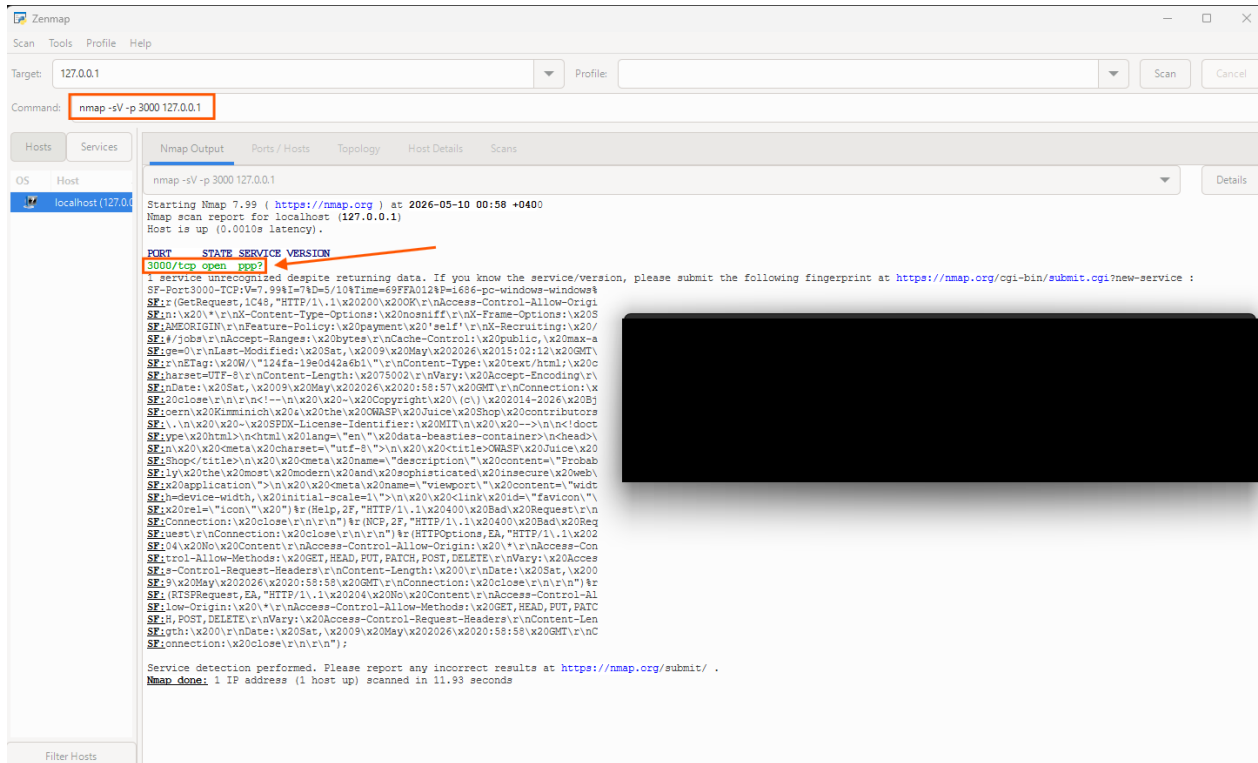


Figure 8 - Full Nmap/Zenmap evidence confirming the local HTTP service on TCP port 3000. The unrelated evidence terminal is precisely redacted.

6.2 HTTP Header Review

Response headers were reviewed for both technology disclosure and missing browser-side security controls. The observations were treated in context: the lab intentionally used HTTP, so HSTS was not expected to provide value in this local-only deployment, but it would be relevant to a production HTTPS deployment.

Header	Observation / Security Relevance
X-Powered-By	Express disclosed; unnecessary technology disclosure in production.
Content-Security-Policy	Not observed or not restrictive enough to provide effective XSS defense.
X-Frame-Options	Not set; framing protections were absent.
Strict-Transport-Security	Not set; local lab was HTTP-only, but production deployments should use HTTPS and HSTS.

```

curl -I http://localhost:3000
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Sat, 09 May 2026 15:02:12 GMT
ETag: W/"124fa-19e0d42a6b1"
Content-Type: text/html; charset=UTF-8
Content-Length: 75002
Vary: Accept-Encoding
Date: Sat, 09 May 2026 19:45:52 GMT
Connection: keep-alive
Keep-Alive: timeout=5

echo DateTime: %date%
DateTime: 09/05/2026

```

Figure 9 - Full HTTP response-header evidence captured during local application fingerprinting; no screenshot content has been cropped.

[illegible]

6.4 Public File Directory Enumeration

Public Portfolio Report | Local Authorized Lab Page 18

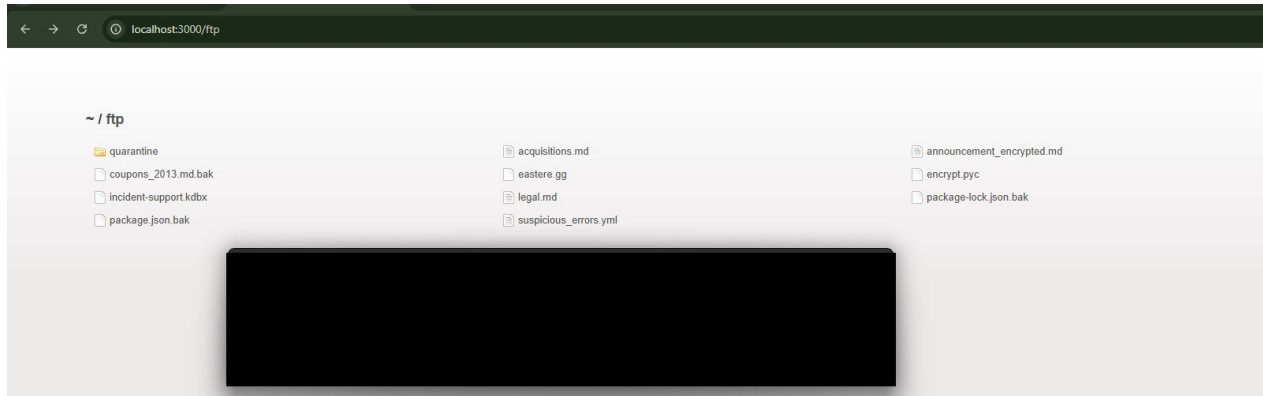


Figure 11 - Full browser evidence of the public /ftp directory listing. The unrelated evidence terminal is precisely redacted.

6.5 Client-Side Route and Asset Review

The application bundle was inspected in the browser Sources view. Route references such as `/#/score-board` and `/#/administration` were visible in client-side code. This demonstrated that route hiding in frontend assets cannot serve as an authorization boundary; the server must enforce access control on protected data and actions.

6.6 Enumeration Summary

Discovery	Risk	Security Impact
Port 3000 open (HTTP)	INFO	Attack surface confirmed.
X-Powered-By: Express	LOW	Technology disclosure aids reconnaissance.
/rest/metrics exposed	HIGH	Runtime diagnostics accessible without authentication.
/ftp directory listing	HIGH	Internal and backup files publicly accessible.
robots.txt references /ftp	MEDIUM	Hidden-from-indexing does not equal access control.
/#/score-board in client bundle	LOW	Hidden route discoverable from client-side code.
/#/administration in client bundle	CRITICAL	Privileged route discoverable; access must be enforced server-side.
/rest/qwertz undocumented route	MEDIUM	Unexpected route exposes detailed error behavior.

7. Vulnerability Assessment and Prioritization

Candidate issues were prioritized using OWASP Top 10 categories, CVSS-based severity, likelihood, and observed impact. The final table below contains only issues that were validated in the local lab or directly supported by observed application behavior.

ID	Finding	OWASP	CVSS	Severity
F01	SQL Injection - Authentication Bypass	A03:2021	9.8	Critical
F02	Broken Access Control - Administrative Access	A01:2021	9.1	Critical
F03	DOM-Based Cross-Site Scripting	A03:2021	8.2	High
F04	Public File Directory / Developer Artifact Exposure	A02:2021	7.5	High
F05	Confidential Document Exposure	A02:2021	7.5	High
F06	Poison Null Byte File Access Bypass	A01:2021	7.2	High
F07	Unauthenticated Metrics Endpoint	A05:2021	6.5	Medium
F08	Verbose Error Handling	A05:2021	5.3	Medium

7.1 Selection Rationale

SQL injection and administrative access were prioritized because they formed the highest-impact attack path. XSS and data exposure demonstrated client-side and confidentiality risks. Metrics exposure and verbose error handling demonstrated security misconfiguration. Poison Null Byte testing was retained as a separate high-severity validation because it showed that file-extension handling could be bypassed through encoded input.

8. Detailed Findings

Each finding below documents the behavior that was observed, the evidence used to confirm it, the likely security impact, the underlying cause, and the recommended remediation. Testing remained limited to the local Juice Shop lab.

F01 - SQL Injection - Authentication Bypass	CRITICAL	CVSS 9.8	A03:2021 Injection
---	----------	----------	--------------------

Description: The login workflow accepted user-controlled input that could alter backend SQL query logic. A crafted email value terminated the intended string and commented out the remainder of the query, allowing an administrator account to be returned without a valid password.

Proof of Concept: The SQL comment payload below was entered into the email field while a normal password value was supplied. The application accepted the request and created an administrator session.

```
admin@juice-sh.op' --
```

1. Open the local Juice Shop login page.
2. Enter the crafted email value in the email field.
3. Submit the request with a normal password value.
4. Confirm that the application creates an administrator session without valid administrator credentials.

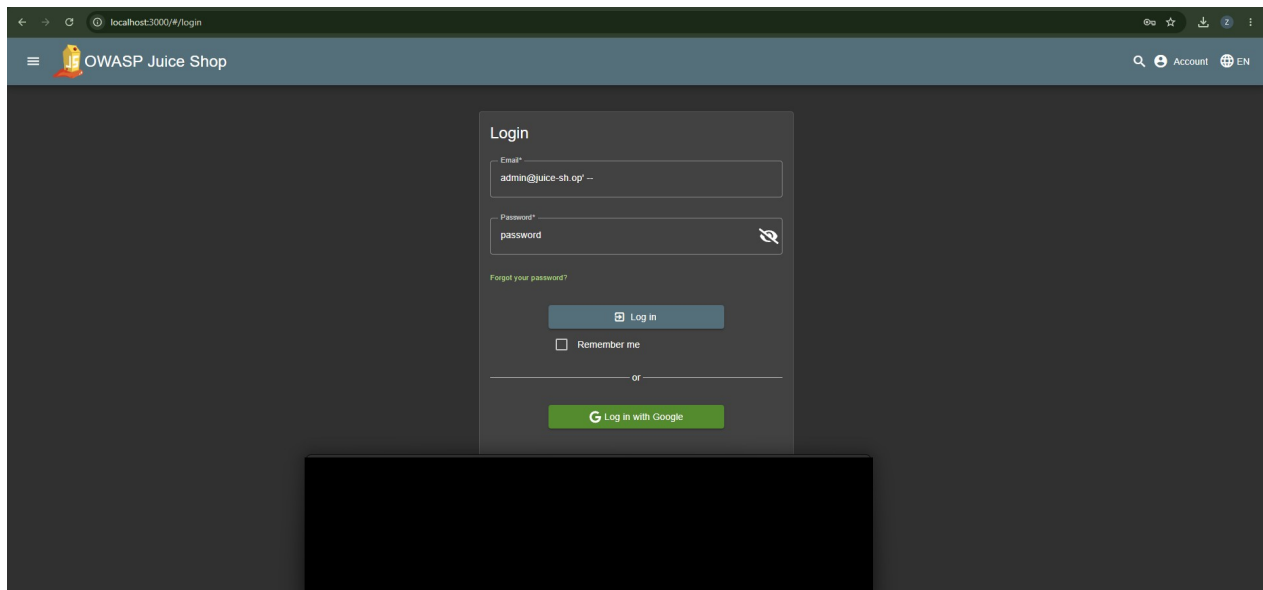


Figure 14a - Full SQL-injection input evidence from the login workflow. The unrelated evidence terminal is precisely redacted.

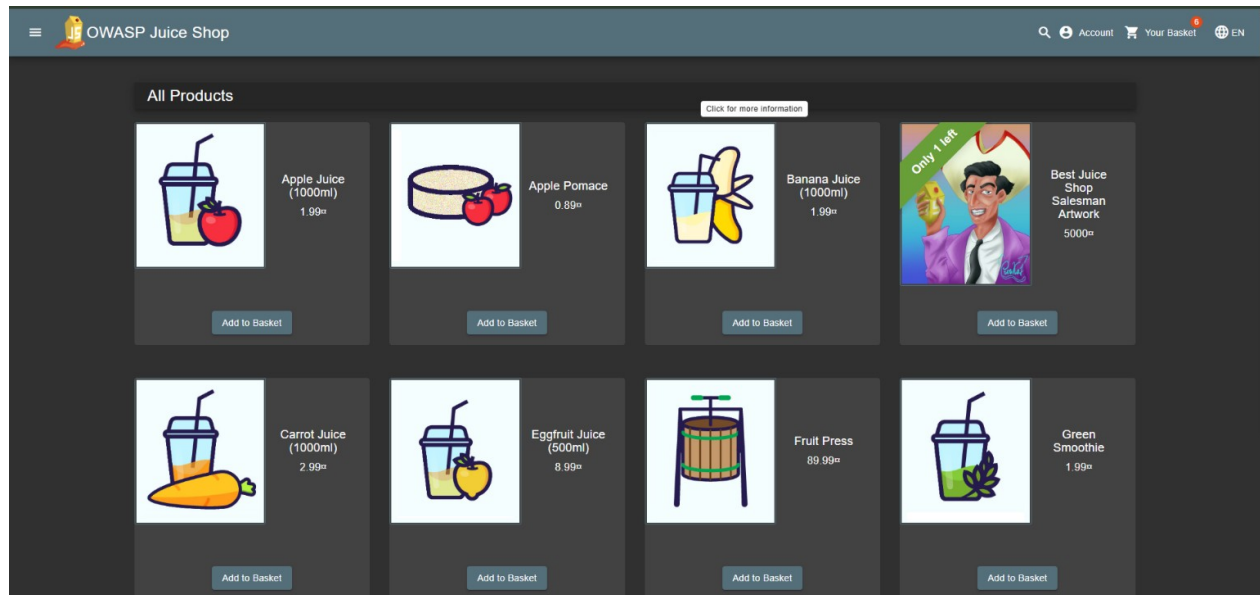


Figure 14b - Full application state after the authentication bypass, confirming successful access to the application.

Impact: Authentication can be bypassed, allowing unauthorized access to privileged application functionality and sensitive data.

Root Cause: User input was incorporated into SQL query logic without safe parameterization.

Remediation: Use prepared statements or ORM-managed query methods for all database access. Add negative tests for common injection patterns and monitor malformed login requests.

Detection: Alert on malformed email input, SQL comment characters in authentication parameters, and unusual successful logins immediately following invalid requests.

F02 - Broken Access Control - Administrative Access

CRITICAL

CVSS 9.1

A01:2021 Broken Access Control

Description: The administrative route was discoverable in client-side application code. After an administrator session was obtained through F01, the administration page exposed registered-user information and customer-feedback management functions.

Validation: The `/#/administration` route was identified during client-side asset review and opened while authenticated through the bypassed administrator session.

`http://localhost:3000/#/administration`

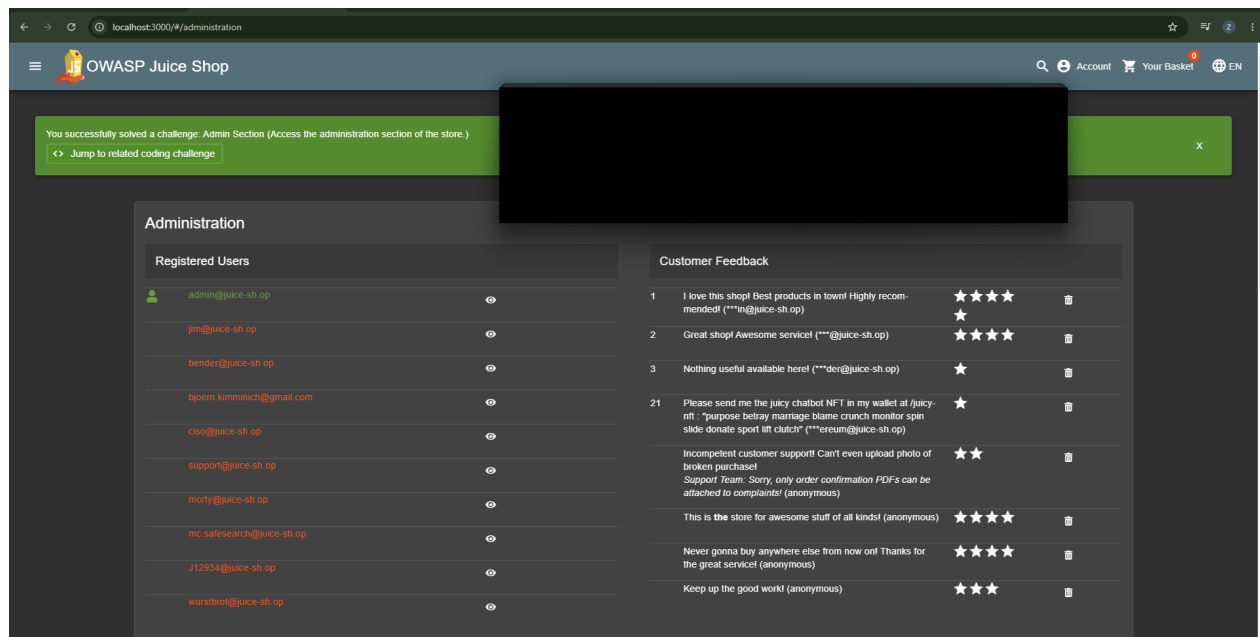


Figure 15 - Full administrative-interface evidence available after authentication bypass. The unrelated evidence terminal is precisely redacted.

Impact: An unauthorized administrator session can access privileged data and functions, producing a direct loss of authorization control.

Root Cause: The demonstrated attack chain combines authentication bypass with privileged application access. Client-side route visibility makes discovery easy, while authorization must still be enforced on every protected server-side API.

Remediation: Validate role and authorization server-side on every privileged API request. Do not rely on hidden frontend routes or client-side guards as security controls.

Detection: Correlate unusual authentication events with immediate access to administrative APIs or administrator-token activity.

```
<iframe src="javascript:alert(`xss`)"></iframe>
```

-

Detection: Monitor search requests containing URL-encoded HTML tags, iframe content, or javascript: URI patterns.

**F04 - Public File Directory /
Developer Artifact
Exposure****HIGH****CVSS 7.5****A02:2021 Data Exposure**

Description: The /ftp directory was directly accessible with directory listing enabled. It exposed internal and developer-oriented files, including backup package metadata, without authentication.

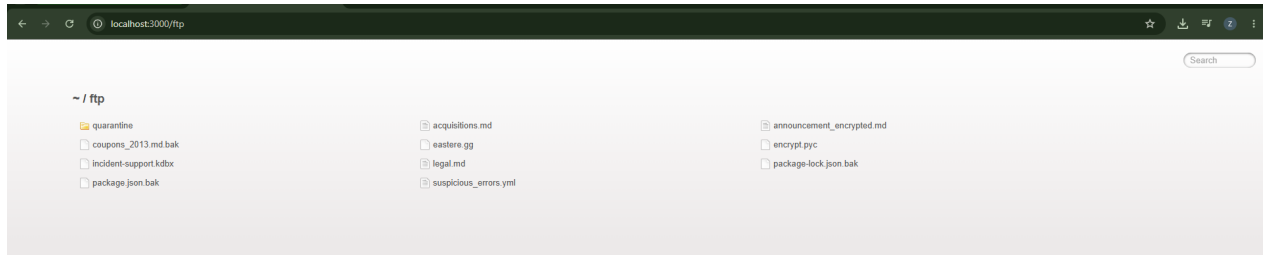


Figure 17 - Full direct browser view of the publicly accessible /ftp directory and exposed files.

Impact: Public developer artifacts can reveal file names, dependency information, internal documentation, and other details useful for further reconnaissance or targeted attacks.

Root Cause: Sensitive and developer files were stored under a web-accessible path with directory listing enabled and no access-control requirement.

Remediation: Remove backup and internal files from the web root, disable directory listing, and add CI/CD checks that prevent backup artifacts from being deployed.

Detection: Alert on rapid enumeration of /ftp and repeated requests for backup extensions such as .bak.

F05 - Confidential
Document Exposure

HIGH

CVSS 7.5

A02:2021 Sensitive Data
Exposure

Description: The acquisitions.md document was accessible directly under /ftp without authentication. The document itself was marked confidential.

GET http://localhost:3000/ftp/acquisitions.md

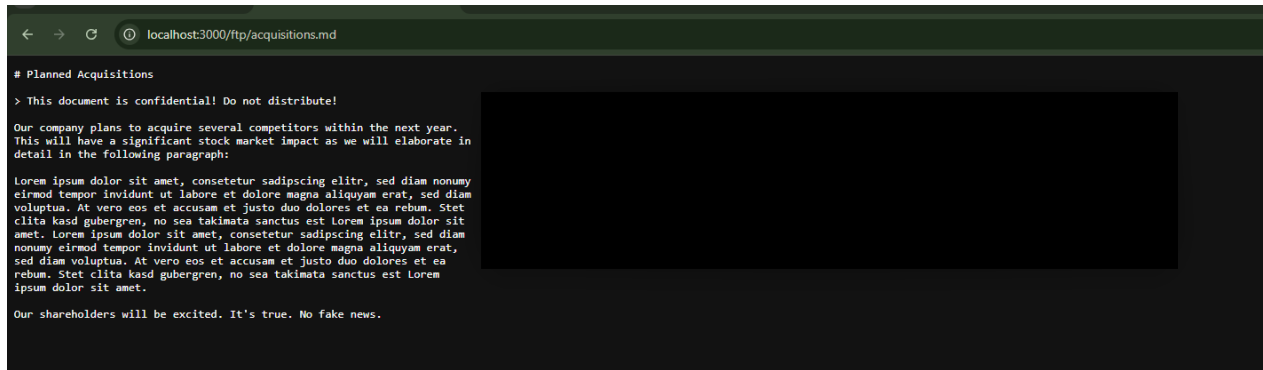


Figure 18 - Full confidential-document retrieval evidence from the public /ftp path. The unrelated evidence terminal is precisely redacted.

Impact: Unauthorized access to internal documents creates a confidentiality risk and may expose business-sensitive information.

Root Cause: The document was stored in a publicly reachable directory with no authentication or authorization requirement.

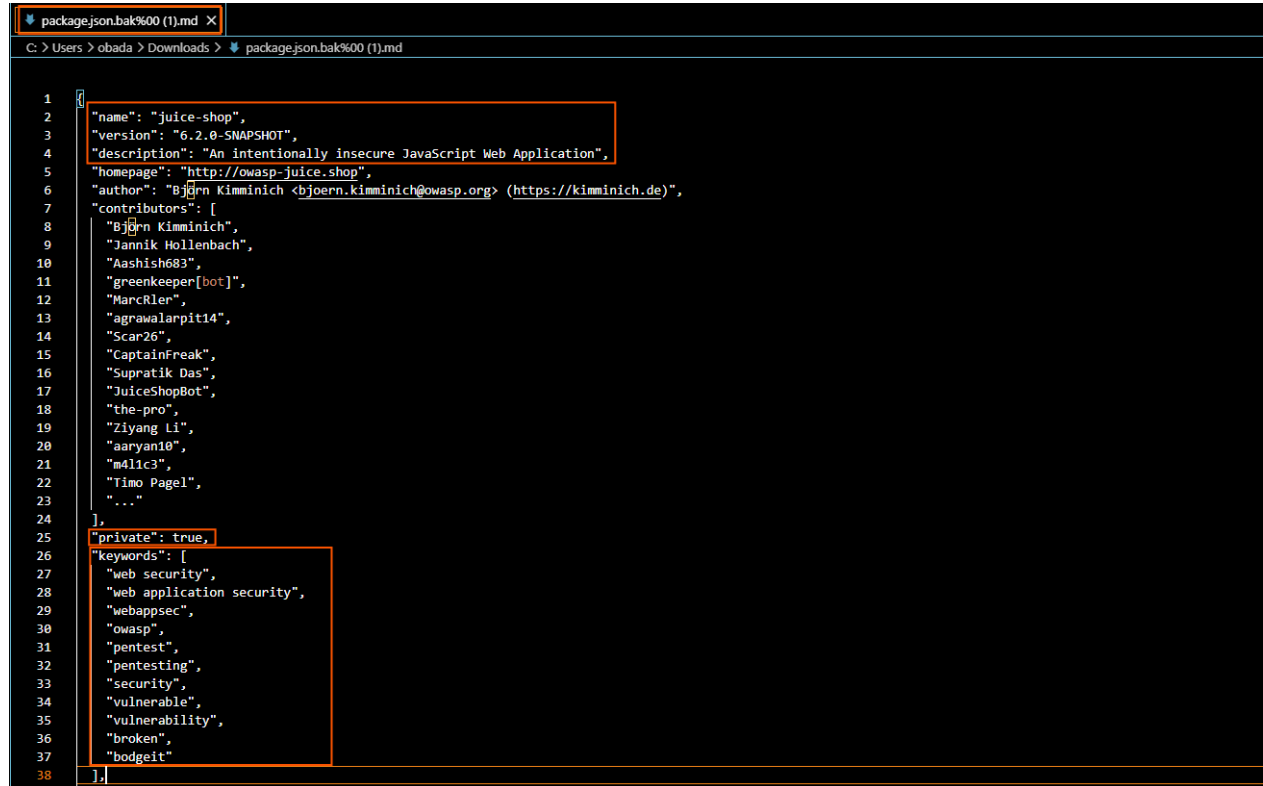
Remediation: Move confidential documents outside the web root and require explicit server-side authorization before any sensitive file is returned.

Detection: Log and alert on unauthenticated access to known internal document paths and rapid browsing of the /ftp directory.

F06 - Poison Null Byte File Access Bypass**HIGH****CVSS 7.2****A01:2021 Broken Access Control**

Description: An encoded null-byte sequence was used in a file path to retrieve a backup file that was otherwise restricted by file-extension handling. The resulting response exposed package metadata from a developer backup.

```
GET /ftp/package.json.bak%2500.md
```



```
1 {
2   "name": "juice-shop",
3   "version": "6.2.0-SNAPSHOT",
4   "description": "An intentionally insecure JavaScript Web Application",
5   "homepage": "http://owasp-juice.shop",
6   "author": "Björn Kimminich <bjoern.kimminich@owasp.org> (https://kimminich.de)",
7   "contributors": [
8     "Björn Kimminich",
9     "Jannik Hollenbach",
10    "Aashish683",
11    "greenkeeper[bot]",
12    "MarcRler",
13    "agnawalarpit14",
14    "Scar26",
15    "CaptainFreak",
16    "Supratik Das",
17    "JuiceShopBot",
18    "the-pro",
19    "Ziyang Li",
20    "aaryan10",
21    "m4lic3",
22    "Timo Pagel",
23    "...",
24  ],
25   "private": true,
26   "keywords": [
27     "web security",
28     "web application security",
29     "webappsec",
30     "owasp",
31     "pentest",
32     "pentesting",
33     "security",
34     "vulnerable",
35     "vulnerability",
36     "broken",
37     "bodgeit"
38 ]
39 }
```

Figure 19 - Full backup package metadata retrieved after the encoded file-path bypass.

Impact: Bypassing file validation can expose developer backups and dependency metadata that supports later vulnerability research.

Root Cause: Input and file-path validation did not safely reject encoded null-byte sequences before file handling.

Remediation: Normalize and validate request paths before file access. Reject encoded null-byte sequences and maintain an allowlist of permitted file types and locations.

Detection: Alert on %00, %2500, and other encoded control sequences in file paths, especially when combined with backup extensions.

F07 - Unauthenticated Metrics Endpoint**MEDIUM****CVSS 6.5****A05:2021 Security Misconfiguration**

Description: The /rest/metrics endpoint returned Prometheus-style runtime information without requiring authentication. Exposed data included request, CPU, memory, process, and event-loop metrics.

GET http://localhost:3000/rest/metrics

```
# HELP file_uploads_count Total number of successful file uploads grouped by file type.
# TYPE file_uploads_count counter
file_uploads_count{file_type="image"} 1
file_uploads_count{file_type="text"} 1

# HELP file_upload_errors Total number of failed file uploads grouped by file type.
# TYPE file_upload_errors counter
file_upload_errors{file_type="image"} 0
file_upload_errors{file_type="text"} 0

# HELP juiceshop_startup_duration_seconds Duration Juiceshop required to perform a certain task during startup
# TYPE juiceshop_startup_duration_seconds gauge
juiceshop_startup_duration_seconds{task="validateConfig",app="juiceshop"} 0.041599562
juiceshop_startup_duration_seconds{task="cleanupTmpFolder",app="juiceshop"} 0.07282277
juiceshop_startup_duration_seconds{task="validatePreconditions",app="juiceshop"} 0.277261839
juiceshop_startup_duration_seconds{task="dataRestorer",app="juiceshop"} 22.85824602
juiceshop_startup_duration_seconds{task="customizeApplication",app="juiceshop"} 0.019736629
juiceshop_startup_duration_seconds{task="customizeEasterEgg",app="juiceshop"} 0.00775245
juiceshop_startup_duration_seconds{task="ready",app="juiceshop"} 22.959

# HELP process_cpu_user_seconds_total Total user CPU time spent in seconds.
# TYPE process_cpu_user_seconds_total counter
process_cpu_user_seconds_total{app="juiceshop"} 34.259957

# HELP process_cpu_system_seconds_total Total system CPU time spent in seconds.
# TYPE process_cpu_system_seconds_total counter
process_cpu_system_seconds_total{app="juiceshop"} 12.568824

# HELP process_cpu_seconds_total Total user and system CPU time spent in seconds.
# TYPE process_cpu_seconds_total counter
process_cpu_seconds_total{app="juiceshop"} 46.827981

# HELP process_start_time_seconds Start time of the process since unix epoch in seconds.
# TYPE process_start_time_seconds gauge
process_start_time_seconds{app="juiceshop"} 1778405777

# HELP process_resident_memory_bytes Resident memory size in bytes.
# TYPE process_resident_memory_bytes gauge
process_resident_memory_bytes{app="juiceshop"} 186224640

# HELP process_virtual_memory_bytes Virtual memory size in bytes.
# TYPE process_virtual_memory_bytes gauge
process_virtual_memory_bytes{app="juiceshop"} 1833820160

# HELP process_heap_bytes Process heap size in bytes.
# TYPE process_heap_bytes gauge
process_heap_bytes{app="juiceshop"} 781238272

# HELP process_open_fds Number of open file descriptors.
# TYPE process_open_fds gauge
process_open_fds{app="juiceshop"} 28

# HELP process_max_fds Maximum number of open file descriptors.
# TYPE process_max_fds gauge
process_max_fds{app="juiceshop"} 1048576

# HELP nodejs_eventloop_lag_seconds Lag of event loop in seconds.
# TYPE nodejs_eventloop_lag_seconds gauge
nodejs_eventloop_lag_seconds{app="juiceshop"} 0

# HELP nodejs_eventloop_lag_min_seconds The minimum recorded event loop delay.
# TYPE nodejs_eventloop_lag_min_seconds gauge
nodejs_eventloop_lag_min_seconds{app="juiceshop"} 0.00136192

# HELP nodejs_eventloop_lag_max_seconds The maximum recorded event loop delay.
# TYPE nodejs_eventloop_lag_max_seconds gauge
nodejs_eventloop_lag_max_seconds{app="juiceshop"} 0.00136192
```

Figure 20 - Full runtime/application metrics evidence exposed without authentication. The unrelated evidence terminal is precisely redacted.

Impact: Operational metrics provide infrastructure and runtime intelligence that can improve an attacker's understanding of the application and reduce uncertainty during reconnaissance.

Root Cause: The monitoring endpoint was enabled without access control.

Remediation: Require authentication or restrict the endpoint to trusted monitoring networks. Disable the endpoint when it is not required.

Detection: Alert on unauthenticated GET requests to /rest/metrics and monitor repeated access from unfamiliar clients.

F08 - Verbose Error Handling**MEDIUM****CVSS 5.3****A05:2021 Security Misconfiguration**

Description: Requesting the undocumented `/rest/qwertz` route produced an HTTP 500 response containing detailed stack traces, internal file paths, and framework information.

GET `http://localhost:3000/rest/qwertz`



Figure 21 - Full detailed Express error-response evidence disclosed to the client. The unrelated evidence terminal is precisely redacted.

Impact: Detailed errors expose framework, route-handler, and internal-path information that can support targeted reconnaissance.

Root Cause: Production-style error suppression was not applied to client responses.

Remediation: Return generic error messages to clients and keep detailed stack traces only in server-side logs. Remove unnecessary framework disclosure such as X-Powered-By.

Detection: Monitor repeated HTTP 500 responses and requests to unexpected routes as indicators of deliberate error probing.

9. Additional Validation Evidence

9.1 Scoreboard Route Discovery

The hidden scoreboard route was identified from client-side application assets. Directly navigating to `/#/score-board` demonstrated that frontend route hiding is not an access-control mechanism. The scoreboard was also used to confirm challenge state as validation progressed.

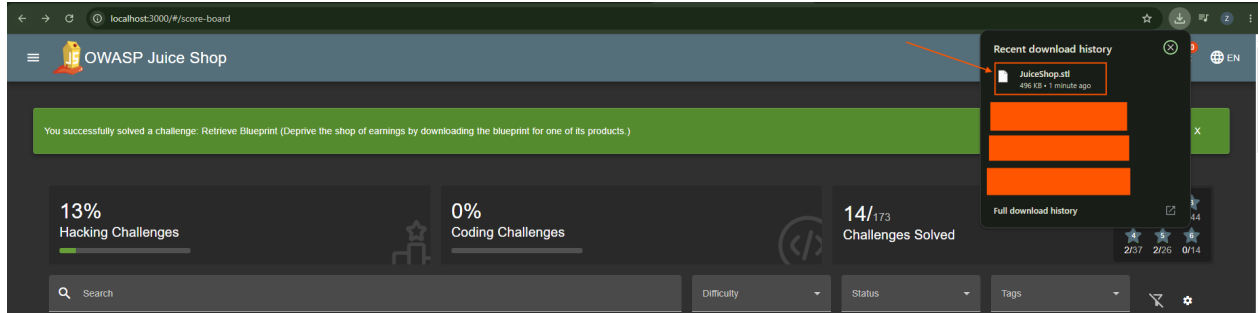


Figure 22 - Scoreboard/challenge-state evidence collected during validation.

9.2 Advanced XSS Payload

A second, more complex payload was executed through the same DOM XSS injection point. The purpose was not to establish a new root cause, but to demonstrate that the same unsafe rendering path could embed external content rather than only trigger a simple alert.



Figure 23 - Full advanced-XSS validation evidence rendered through the same unsafe DOM injection path. The unrelated evidence terminal is precisely redacted.

10. Post-Exploitation Impact and Attack Chain

Post-exploitation in this assessment was limited to demonstrating application-level impact after a successful exploit. It did not include operating-system persistence or destructive actions. The most important attack path began with SQL injection and ended with privileged administrative access, while file and monitoring weaknesses provided independent information-disclosure paths.

Step	Observed Result
1. SQL Injection	Authentication was bypassed and an administrator session was obtained.
2. Administrative Access	Privileged user and feedback-management functionality became accessible.
3. Public File Exposure	Internal documents and backup files were available under /ftp.
4. Metrics Exposure	Unauthenticated runtime data disclosed application behavior and process information.
5. Backup Retrieval	Encoded file-path input allowed access to package metadata useful for reconnaissance.

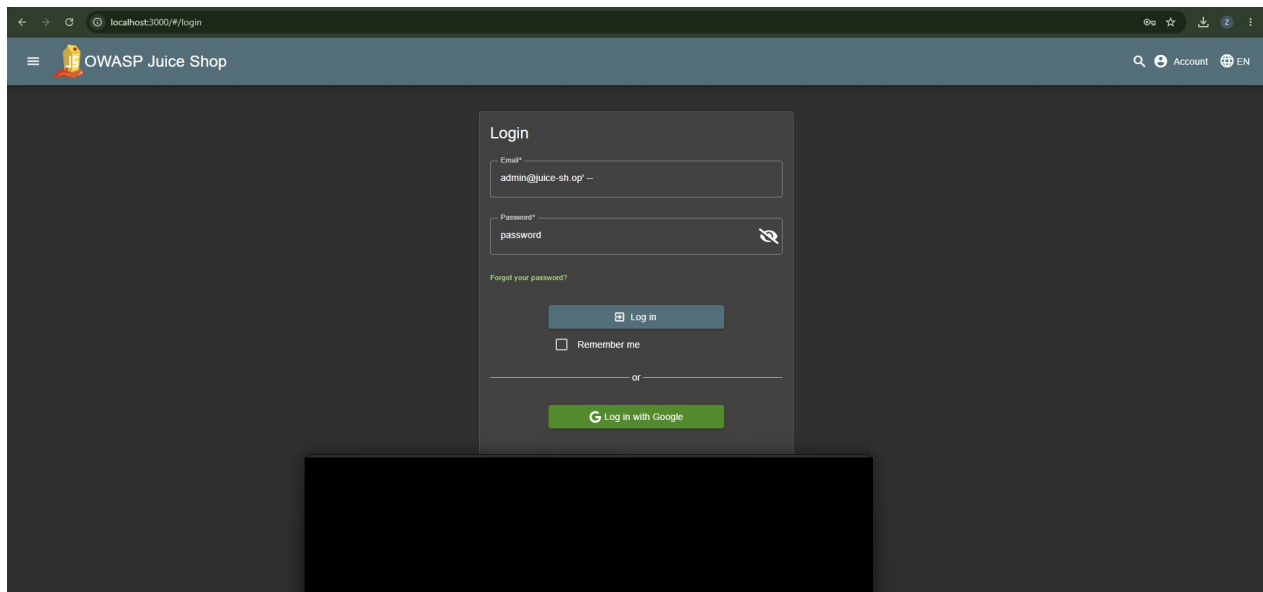


Figure 24 - Full login-stage evidence for the authentication-bypass attack path.

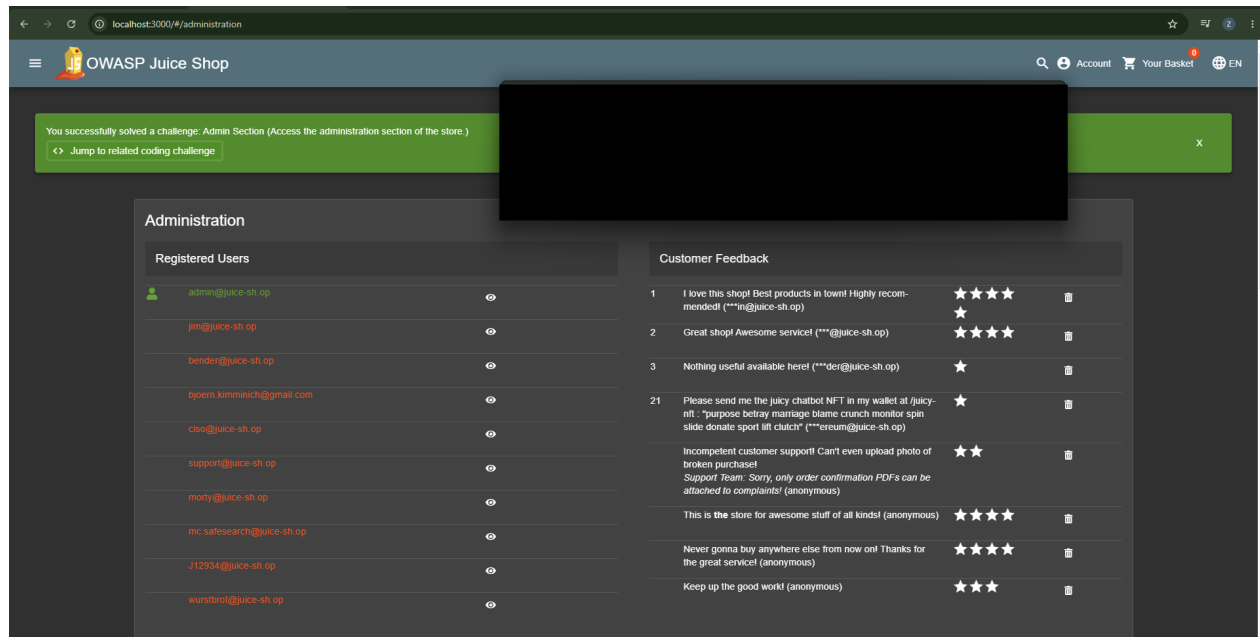


Figure 25 - Full privileged administrative view reached through the validated attack chain.

10.1 Business-Relevant Risk

- Loss of authentication and authorization can expose privileged actions and sensitive records.
- Internal file disclosure can reveal business information and application dependency details.
- Client-side XSS can affect user trust and support browser-based attacks.
- Operational data and verbose errors reduce the amount of uncertainty an attacker faces during reconnaissance.
- Multiple lower-level weaknesses can compound when combined with a critical authentication flaw.

10.2 Attack Chain Interpretation

The validated weaknesses were not isolated. SQL injection created an unauthorized administrator session. That session made privileged functionality reachable. Separately, the public file directory and metrics endpoint exposed information without requiring administrator access. The result is a layered risk picture involving confidentiality, integrity, and reconnaissance exposure rather than a single standalone bug.

11. Detection and Log Analysis

The same actions used to validate the findings left useful evidence in HTTP and application logs. These observables can be converted into SIEM, WAF, or application-monitoring detections. Docker logs were reviewed to connect security-test actions with application-side events and errors.

Activity	Observable Evidence
SQL Injection Login	POST to /rest/user/login containing malformed email input and SQL comment characters.
DOM XSS Search	Search requests containing URL-encoded HTML or iframe content.
FTP Enumeration	Multiple GET requests to /ftp and sensitive file names in a short time window.
Null Byte Bypass	Requests containing %00 or %2500 in a file path.
Metrics Access	Unauthenticated GET requests to /rest/metrics.
Error Probing	Repeated HTTP 500 responses or requests to unexpected endpoints such as /rest/qwertz.
Privileged Access	Administrator-token activity immediately following unusual authentication behavior.

```

C:\WINDOWS\system32\cmd. x + v

echo DateTime: %date%
DateTime: 19/05/2026

docker logs -tail 80
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:196:5)
Error: Only .md and .pdf files are allowed!
at verify (/juice-shop/build/routes/fileServer.js:59:18)
at /juice-shop/build/routes/fileServer.js:43:13
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at param (/juice-shop/node_modules/express/lib/router/index.js:365:14)
at param (/juice-shop/node_modules/express/lib/router/index.js:376:14)
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:196:5)
Error: Only .md and .pdf files are allowed!
at verify (/juice-shop/build/routes/fileServer.js:59:18)
at /juice-shop/build/routes/fileServer.js:43:13
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at param (/juice-shop/node_modules/express/lib/router/index.js:365:14)
at param (/juice-shop/node_modules/express/lib/router/index.js:376:14)
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:196:5)
info: Solved 2-star loginAdminChallenge (Login Admin)
info: Cheat score for tutorial loginAdminChallenge solved in 20min (expected ~2min) with hints allowed: 0
info: Solved 1-star localXssChallenge (DOM XSS)
info: Cheat score for tutorial localXssChallenge solved in 18min (expected ~1min) with hints allowed: 0
info: Solved 1-star xssBonusChallenge (Bonus Payload)
info: Cheat score for tutorial xssBonusChallenge solved in 2min (expected ~1min) with hints allowed: 0
info: Solved 1-star exposedMetricsChallenge (Exposed Metrics)
info: Cheat score for exposedMetricsChallenge solved in 7min (expected ~2min) with hints allowed: 0
Error: Unexpected path: /rest/qwertz
at /juice-shop/build/routes/angular.js:42:18
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/build/routes/verify.js:288:5

```

Figure 26a - Full Docker/application log evidence, with only personal and session-specific command-line identifiers precisely redacted.

```

C:\WINDOWS\system32\cmd. X + v
info: Cheat score for tutorial loginAdminChallenge solved in 20min (expected ~2min) with hints allowed: 0
info: Solved 1-star localXssChallenge (DOM XSS)
info: Cheat score for tutorial localXssChallenge solved in 18min (expected ~1min) with hints allowed: 0
info: Solved 1-star xssBonusChallenge (Bonus Payload)
info: Cheat score for tutorial xssBonusChallenge solved in 2min (expected ~1min) with hints allowed: 0
info: Solved 1-star exposedMetricsChallenge (Exposed Metrics)
info: Cheat score for exposedMetricsChallenge solved in 7min (expected ~2min) with hints allowed: 0
Error: Unexpected path: /rest/quertz
    at /juice-shop/build/routes/angular.js:42:18
    at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
    at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
    at /juice-shop/node_modules/express/lib/router/index.js:286:9
    at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
    at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
    at /juice-shop/build/routes/verify.js:288:5
    at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
    at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
    at /juice-shop/node_modules/express/lib/router/index.js:286:9
    at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
    at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
    at /juice-shop/build/routes/verify.js:111:5
    at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
    at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
    at /juice-shop/node_modules/express/lib/router/index.js:286:9
    at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
    at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
    at logger (/juice-shop/node_modules/morgan/index.js:144:5)
    at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
    at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
    at /juice-shop/node_modules/express/lib/router/index.js:286:9
info: Solved 2-star adminSectionChallenge (Admin Section)
info: Cheat score for tutorial adminSectionChallenge solved in 16min (expected ~2min) with hints allowed: 0
info: Solved 4-star forgottenDevBackupChallenge (Forgotten Developer Backup)
info: Cheat score for forgottenDevBackupChallenge solved in 2min (expected ~8min) with hints allowed and 100% expected preceding URL interaction: 0.7942833333333333
info: Solved 4-star nullByteChallenge (Poison Null Byte)
info: Cheat score for coupled nullByteChallenge solved in 0min (expected ~0min) with hints allowed: 0
info: Solved 1-star privacyPolicyChallenge (Privacy Policy)
info: Cheat score for trivial tutorial privacyPolicyChallenge solved in 7min (expected ~0min) with hints allowed: 0
info: Solved 2-star feedbackChallenge (Five-Star Feedback)
info: Cheat score for feedbackChallenge solved in 2min (expected ~4min) with hints allowed: 0.3792208333333333
info: Solved 5-star extraLanguageChallenge (Extra Language)
info: Cheat score for extraLanguageChallenge solved in 8min (expected ~10min) with hints allowed: 0.15310666666666666
info: Solved 5-star retrieveBlueprintChallenge (Retrieve Blueprint)
info: Cheat score for retrieveBlueprintChallenge solved in 9min (expected ~10min) with hints allowed: 0.09384499999999999
Error
    at Database.<anonymous> (/juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:185:27)
    at /juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:183:50
    at new Promise (<anonymous>)
    at Query.run (/juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:183:12)
    at /juice-shop/node_modules/sequelize/lib/sequelize.js:315:28
    at process.processTicksAndRejections (node:internal/process/task_queues:104:5)

```

Figure 26b - Continuation of the full application log evidence showing challenge and error events.

11.1 Recommended Detection Controls

- Use WAF or application-layer rules for common SQL injection characters and patterns in authentication parameters.
- Alert on encoded null-byte sequences and unusual file-extension combinations.
- Alert when unauthenticated clients access /rest/metrics or enumerate /ftp.
- Monitor HTTP 500 spikes for possible error-based reconnaissance.
- Correlate malformed or failed logins with immediate privileged-token use.
- Centralize web and application logs so events can be correlated across the full attack sequence.
- Monitor JWT usage patterns for privileged tokens created immediately after unusual authentication events.

11.2 Defensive Evasion Awareness

From a defensive perspective, attackers may try to fragment evidence by rotating source addresses, encoding payloads, or blending requests into high-traffic periods. No log deletion or track-covering was performed in this assessment. The purpose of this consideration is to show why detection should combine multiple signals rather than depend on a single exact payload signature.

12. Remediation Plan

Remediation is ordered by exploitability and impact. Critical authentication and authorization weaknesses should be addressed before lower-severity information disclosures. The plan below maps each major issue to an implementation-focused control.

#	Action	Priority	Implementation Guidance
1	Implement Parameterized Queries	CRITICAL	Replace string-concatenated SQL with prepared statements or ORM-managed queries.
2	Enforce Server-Side Authorization	CRITICAL	Validate roles on every privileged API endpoint; do not rely on client-side routing for security.
3	Fix Client-Side XSS	HIGH	Use safe output encoding, avoid unsafe HTML bindings, sanitize required HTML, and add CSP.
4	Remove Public /ftp Artifacts	HIGH	Move backups and internal files outside the web root and disable directory listing.
5	Restrict Monitoring Endpoints	HIGH	Require authentication or trusted-network access for /rest/metrics.
6	Fix Null Byte Validation	HIGH	Normalize paths and reject encoded null-byte sequences before file handling.
7	Patch Dependencies	HIGH	Review dependency audit results and establish recurring dependency scanning.
8	Suppress Verbose Errors	MEDIUM	Return generic client errors while retaining detailed server-side logs.
9	Add Security Headers	MEDIUM	Deploy CSP, X-Content-Type-Options, framing protection, and HSTS where HTTPS is used.
10	Centralize Logging & Alerting	MEDIUM	Detect injection, null-byte access, metrics exposure, repeated 500 errors, and unusual admin sessions.

12.1 Remediation Verification Priorities

- Retest SQL injection first because it is the entry point to the highest-impact attack path.
- Verify that privileged APIs independently enforce server-side role checks.
- Retest public file access and null-byte handling after directory and path-validation changes.
- Confirm that XSS payloads are rendered as inert text.
- Verify that monitoring endpoints and error messages expose only intended information.
- Confirm that new detection controls generate usable alerts without relying on one exact test payload.

13. Retest Criteria and Conclusion

13.1 Retest Criteria

- SQL injection payloads are rejected and do not create an authenticated session.
- Privileged APIs return 403 Forbidden for users without the required server-side role.
- The /ftp directory is removed or returns 403/404 and directory listing is disabled.
- XSS payloads are rendered as inert text rather than executable markup.
- /rest/metrics requires authentication or is unavailable to untrusted clients.
- Encoded null-byte sequences are rejected before reaching file-processing logic.
- Unexpected routes return generic errors without stack traces or internal paths.

13.2 Conclusion

The local Juice Shop assessment confirmed exploitable weaknesses across authentication, authorization, input handling, sensitive-file exposure, monitoring, and error handling. SQL injection was the highest-impact issue because it enabled an administrator session without valid credentials. Administrative access then exposed privileged functionality, while the public file directory and metrics endpoint independently leaked sensitive and operational information.

The exercise also demonstrated the value of combining offensive validation with defensive analysis. Remediation reduces the attack surface, but logging and alerting are still needed to identify suspicious requests and privilege changes. A focused retest should verify each critical and high-severity fix before the application is considered remediated.

Appendix A. Supporting Evidence

The following additional screenshots are included to preserve the step-by-step evidence trail while keeping the main findings section readable. All privacy-sensitive identifiers have been redacted where necessary.

A.1 Additional Enumeration Evidence

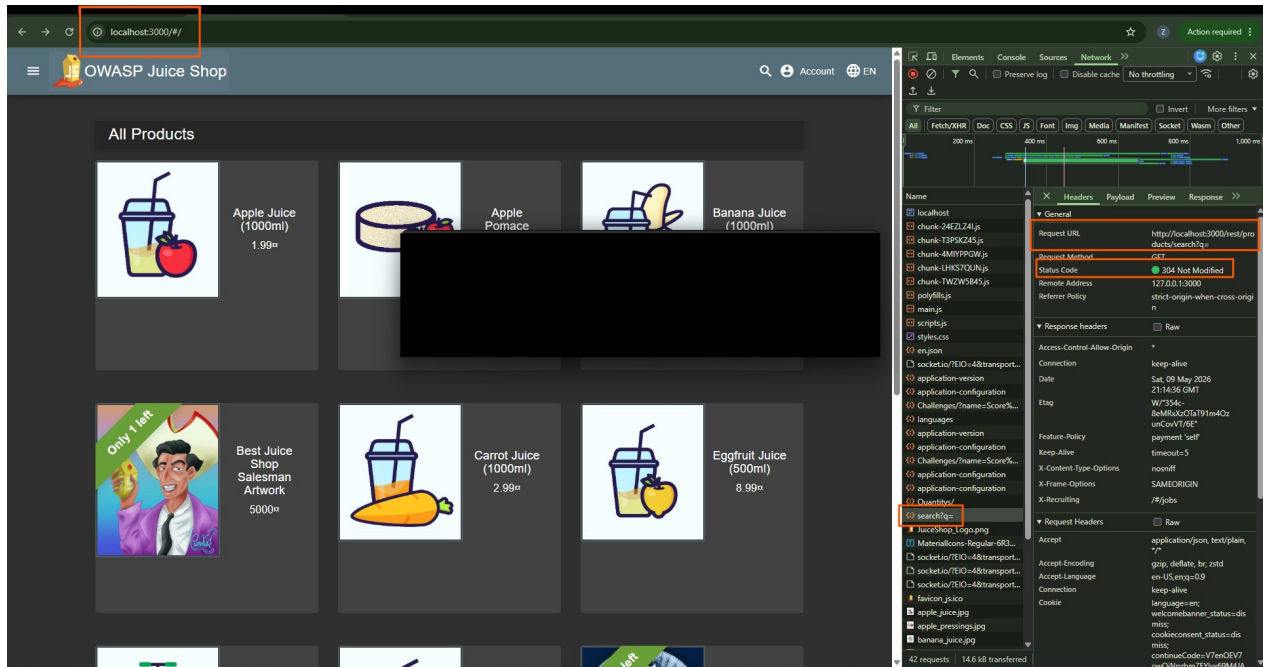


Figure A1 - Full browser developer-tools inspection and API enumeration evidence.

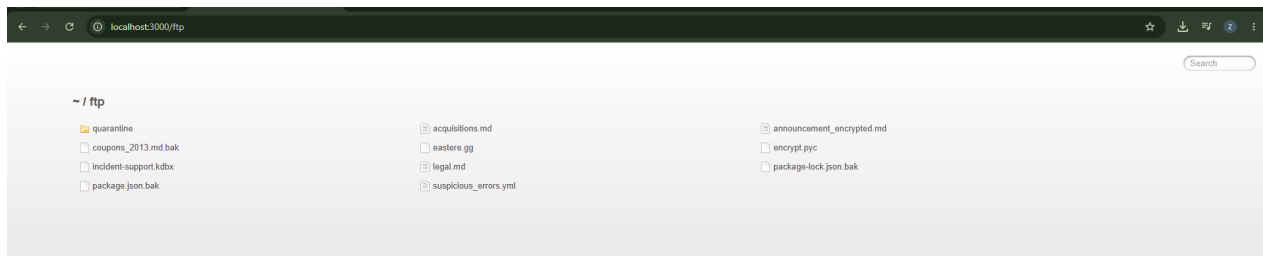
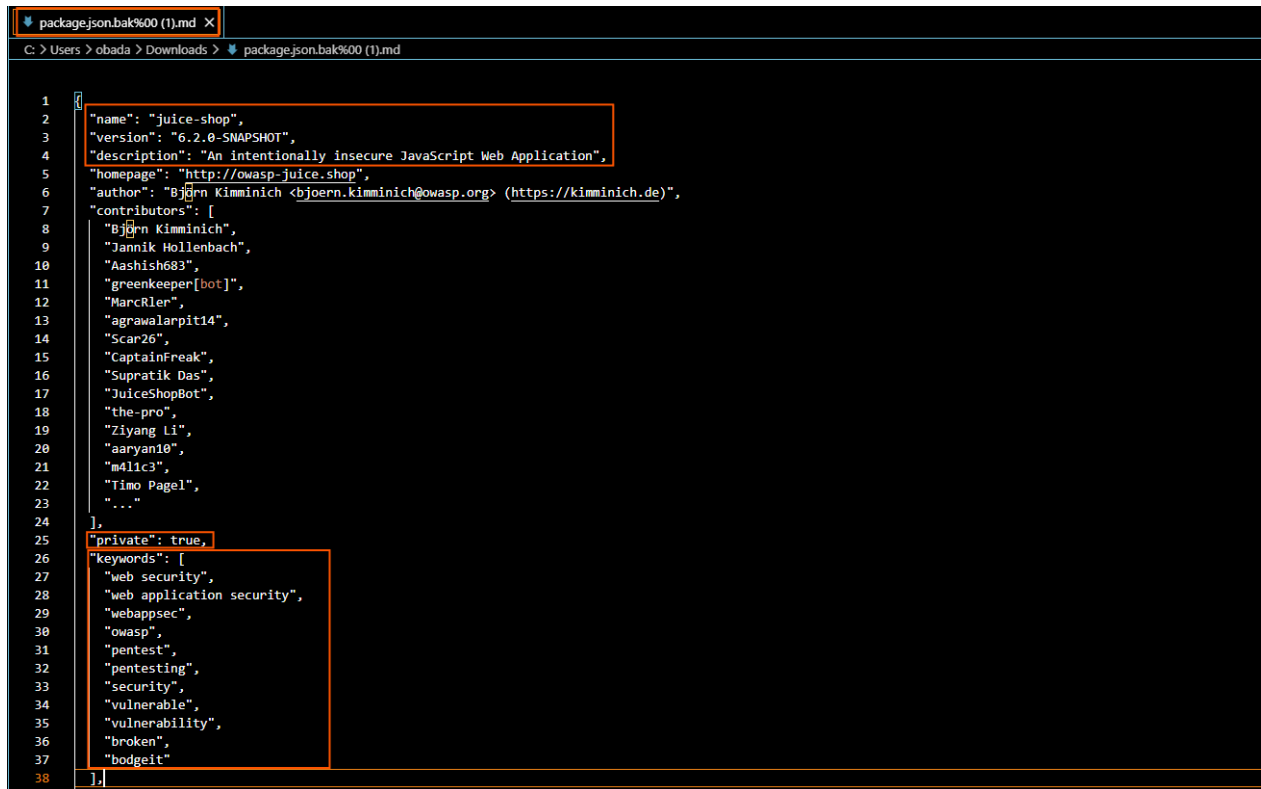


Figure A2 - Full exposed /ftp directory viewed directly in the browser.

A.2 Additional Validation Evidence

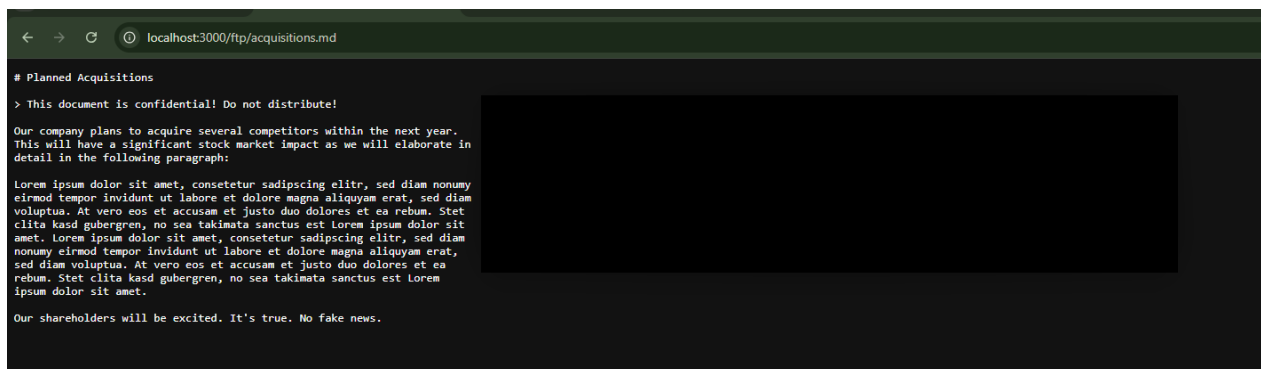


```

1  {
2    "name": "juice-shop",
3    "version": "6.2.0-SNAPSHOT",
4    "description": "An intentionally insecure JavaScript Web Application",
5    "homepage": "http://owasp-juice.shop",
6    "author": "Björn Kimminich <bjoern.kimminich@owasp.org> (https://kimminich.de)",
7    "contributors": [
8      "Björn Kimminich",
9      "Jannik Hollenbach",
10     "Aashish683",
11     "greenkeeper[bot]",
12     "MarcRler",
13     "agrawalarpit14",
14     "Scar26",
15     "CaptainFreak",
16     "Supratik Das",
17     "JuiceShopBot",
18     "the-pro",
19     "Ziyang Li",
20     "aaryan10",
21     "m4llc3",
22     "Timo Pagel",
23     "...",
24   ],
25   "private": true,
26   "keywords": [
27     "web security",
28     "web application security",
29     "webappsec",
30     "owasp",
31     "pentest",
32     "pentesting",
33     "security",
34     "vulnerable",
35     "vulnerability",
36     "broken",
37     "bodgeit"
38   ],

```

Figure A3 - Full exposed backup package metadata used as supporting evidence.



```

<  →  ↻  localhost:3000/ftp/acquisitions.md

# Planned Acquisitions

> This document is confidential! Do not distribute!

Our company plans to acquire several competitors within the next year.
This will have a significant stock market impact as we will elaborate in
detail in the following paragraph:

Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy
eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam
voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet
clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit
amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam
nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat,
sed diam voluptua. At vero eos et accusam et justo duo dolores et ea
rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem
ipsum dolor sit amet.

Our shareholders will be excited. It's true. No fake news.

```

Figure A4 - Full publicly accessible confidential-document evidence used as supporting evidence.

A.3 Challenge-State Evidence

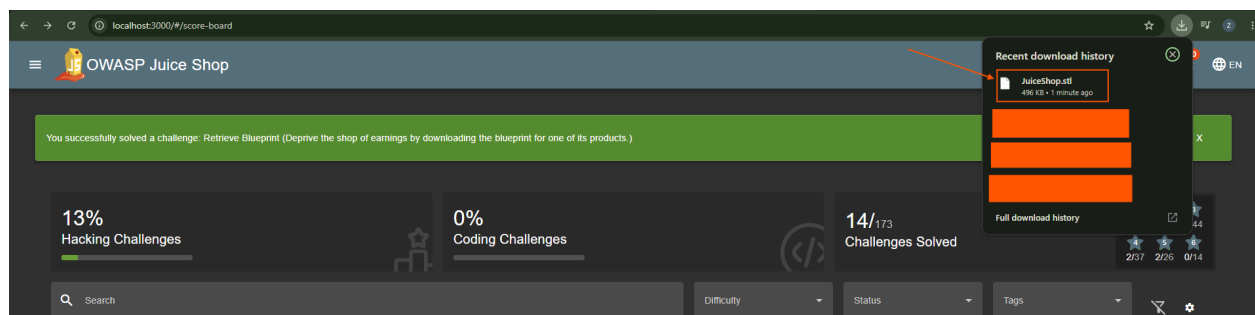


Figure A5 - Additional scoreboard/challenge-state evidence collected during validation.

Challenge-state screenshots were used as supporting confirmation that the tested behavior was accepted by the intentionally vulnerable application. They supplement, rather than replace, the direct technical evidence shown in the detailed findings.

A.4 Additional Redacted Lab Evidence

These screenshots preserve additional application-state evidence from the original lab record. Solid black boxes intentionally cover unrelated evidence-session overlays and personal identifiers; the application content itself has not been altered.

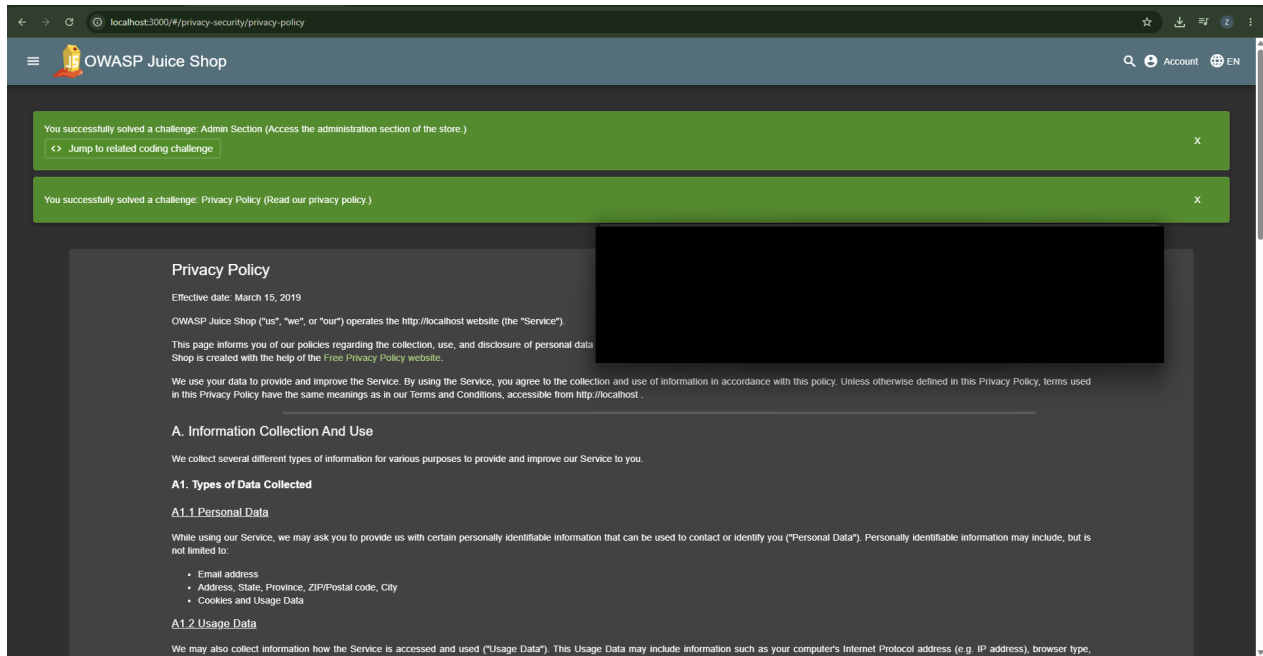


Figure A6 - Additional Juice Shop challenge-state evidence with the unrelated evidence-session terminal fully redacted.

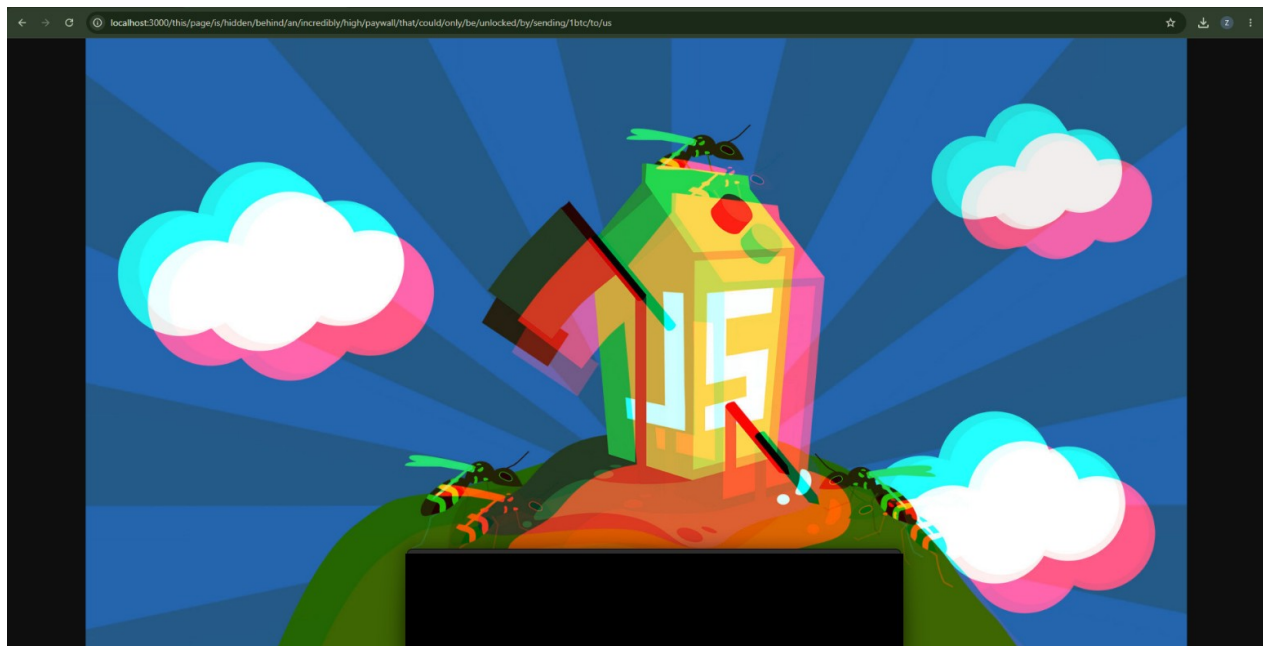


Figure A7 - Additional hidden-page validation evidence with the unrelated evidence-session terminal fully redacted.

Appendix B. Evidence Coverage Index

This index accounts for the original evidence sequence retained from the lab. Evidence that is already shown in the main body is marked as Main. Additional redacted source screenshots are reproduced in Appendix C so a reviewer can trace the assessment step by step. One source image is intentionally not reproduced because it contained only personal/session-identification metadata and no technical evidence.

Evidence	Technical Purpose	Public Portfolio Coverage
1	Docker deployment and container status	Main - Figure 1
2	Session-identification marker	Not reproduced - privacy-only metadata; no technical evidence
3	Baseline Juice Shop scoreboard	Main - Figure 2
4-7	Passive OSINT searches and source discovery	Main - Figures 3-4; raw redacted evidence in Appendix C
8-13	HTTP/application fingerprinting and package metadata	Main - Figures 5-6; raw redacted evidence in Appendix C
14-20	Node.js, Express, Angular, and SQLite advisory research	Main - Figure 7; raw redacted evidence in Appendix C
21	Nmap/Zenmap local service scan	Main - Figure 8; raw redacted evidence in Appendix C
22	HTTP header and browser inspection	Main - Figure 9; raw redacted evidence in Appendix C
23	REST/API route enumeration	Main - Figure 10; raw redacted evidence in Appendix C
24	Public /ftp directory discovery	Main - Figure 11; raw redacted evidence in Appendix C
25	Client-side route/source review	Appendix C
26-27	Candidate vulnerability and hidden-route validation state	Appendix C
28-29	SQL injection and resulting privileged session	Main - Figures 14, 24-25; raw redacted evidence in Appendix C
30-31	DOM XSS and advanced XSS validation	Main - Figures 16 and 23; raw redacted evidence in Appendix C
32	Unauthenticated metrics endpoint	Main - Figure 20; raw redacted evidence in Appendix C
33-34	Confidential-file access and validation state	Main - Figure 18; raw redacted evidence in Appendix C
35	Verbose error response	Main - Figure 21; raw redacted evidence in Appendix C
36	Administrative access	Main - Figures 15 and 25; raw redacted evidence in Appendix C
37-38	Backup-file/null-byte validation	Main - Figure 19; raw redacted evidence in Appendix C
39-40	Post-exploitation file/admin state	Appendix C
41-42	Docker/application log evidence	Main - Figure 26; raw redacted evidence in Appendix C
43-45	Additional solved-state / hidden-page evidence	Appendix A and Appendix C

Appendix C. Extended Evidence Gallery

This gallery preserves the detailed evidence trail behind the summarized figures in the main report. The screenshots are full-frame redacted portfolio copies of the original lab evidence. No source screenshot is cropped in this gallery. Solid black boxes are confined to the original terminal/evidence-overlay footprint or to specific command-line identifiers, so no additional application evidence is obscured. Captions explain what each image contributes to the assessment so the evidence can be reviewed without relying on the original lab instructions.

C.1 Passive Reconnaissance

The first evidence set shows how public information was used to understand the application before deeper local testing. These searches were reconnaissance inputs, not findings by themselves.

C.1.1 Official OWASP Project Discovery

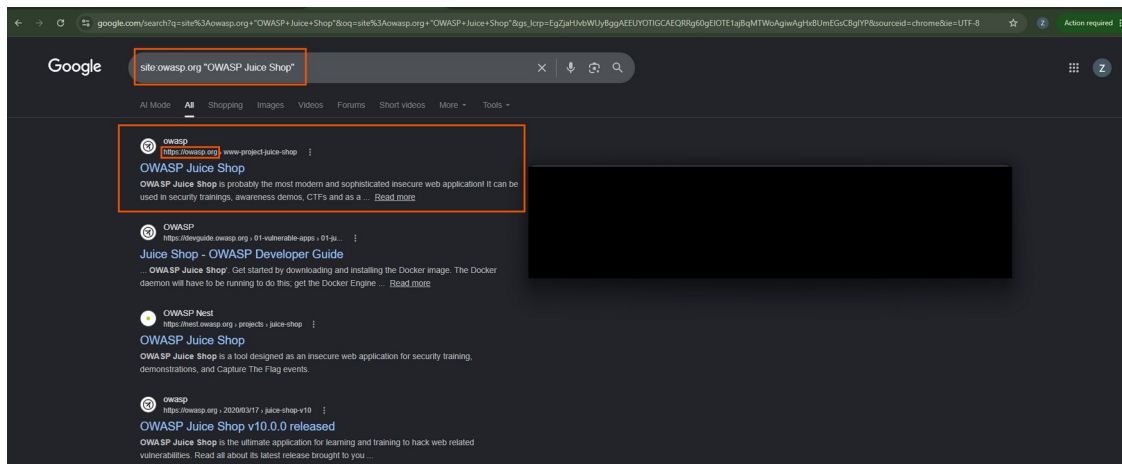


Figure C1 - Search result used to locate the official OWASP Juice Shop project and establish an authoritative source for architecture and project information. The unrelated local session window is redacted.

C.1.2 Companion Guide Discovery

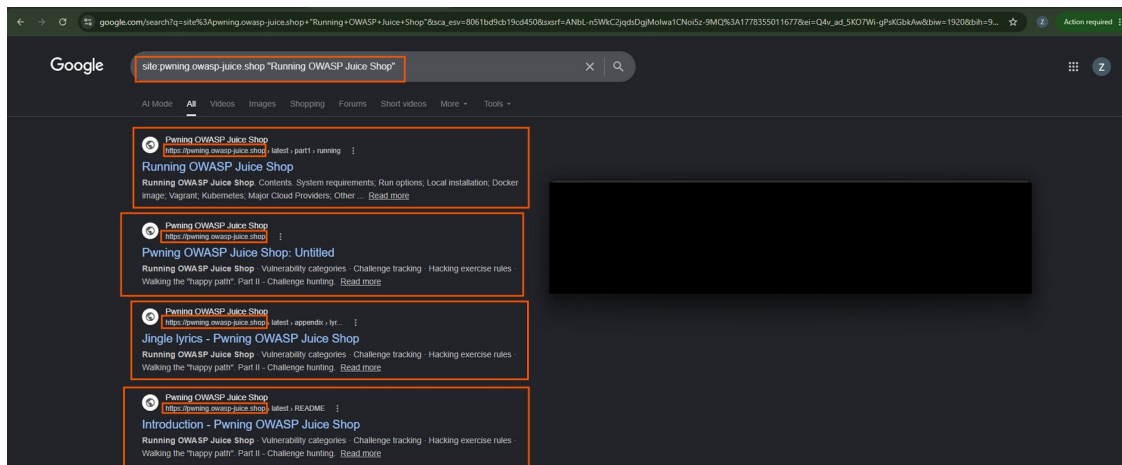


Figure C2 - Search result used to locate the official Juice Shop companion material and understand challenge categories and expected attack-surface themes. Personal/session metadata is redacted.

C.1.3 Public Repository Metadata Search

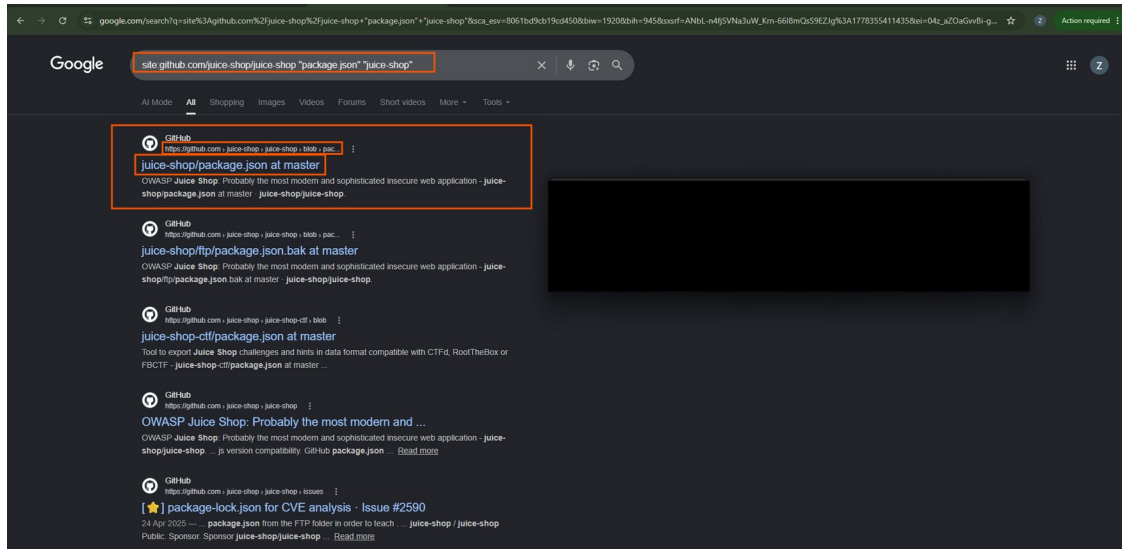


Figure C3 - Public repository search used to locate package/dependency metadata before local exploitation. The evidence supported later technology fingerprinting but was not treated as proof of exploitability.

C.1.4 CTF/Challenge Documentation Search

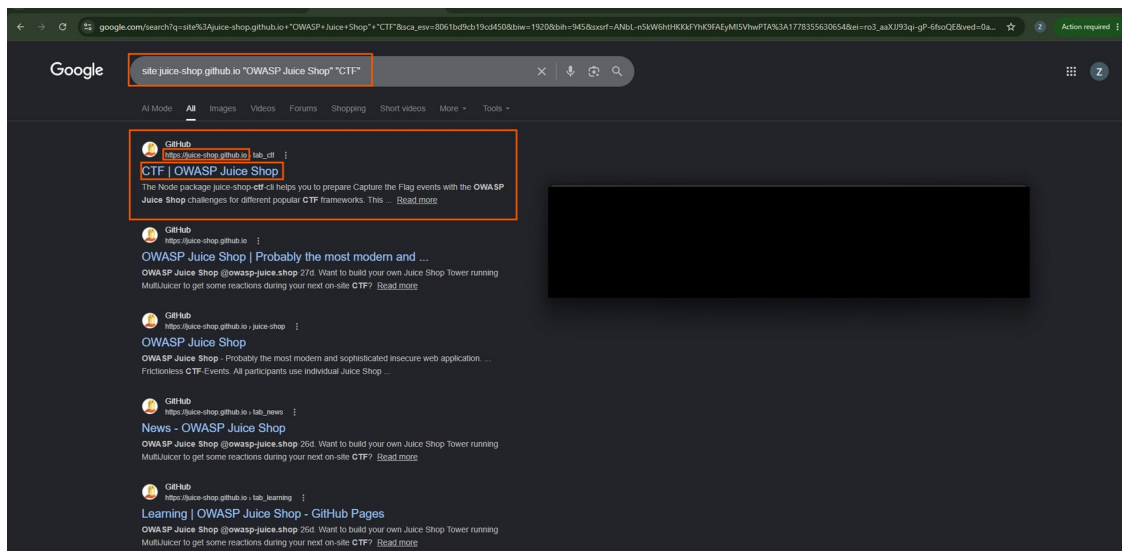


Figure C4 - Passive search for Juice Shop challenge documentation used to identify relevant vulnerability categories and prioritize local validation targets.

C.2 Technology Fingerprinting and Dependency Evidence

Technology fingerprinting combined HTTP behavior, browser inspection, and public package metadata. The goal was to build a defensible picture of the stack and then research relevant security advisories.

C.2.1 HTTP Response Evidence

```

curl -I http://localhost:3000
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Sat, 09 May 2026 15:02:12 GMT
ETag: W/"124fa-19e0d42a6b1"
Content-Type: text/html; charset=UTF-8
Content-Length: 75002
Vary: Accept-Encoding
Date: Sat, 09 May 2026 19:45:52 GMT
Connection: keep-alive
Keep-Alive: timeout=5

echo DateTime: %date%
DateTime: 09/05/2026

```

Figure C5 - Command-line HTTP response evidence showing application response headers used during technology fingerprinting. Privacy/session metadata is blacked out while response content remains visible.

C.2.2 Browser and Developer-Tools Fingerprinting

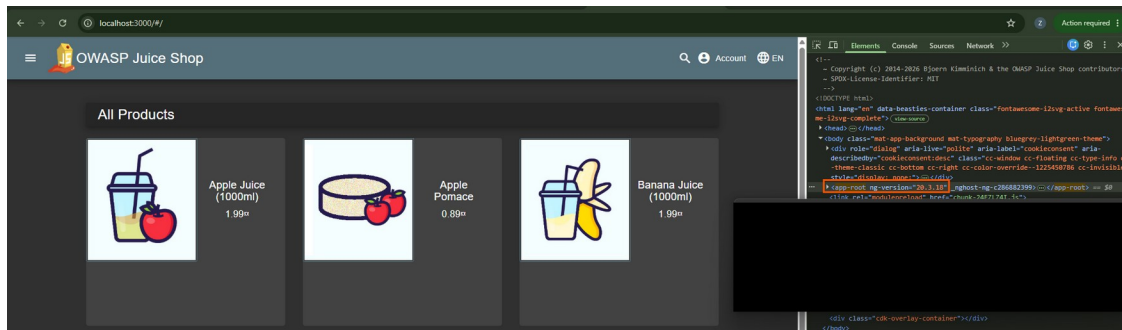


Figure C6 - Browser/Developer Tools evidence used to inspect the application and confirm framework-related behavior observed from the local target.

C.2.3 Node.js Engine Metadata

```

juice-shop / package.json
Code Blame 283 lines (283 loc) · 8.26 KB
254 "socket.io-client": "~3.1.3",
255 "source-map-support": "~0.5.21",
256 "ts-jest": "~29.2.5",
257 "ts-node": "~10.9.2",
258 "typescript": "~5.3.3"
259 },
260 "engines": {
261   "node": "20 - 24"
262 },
263 "os": [
264   "win32",
265   "linux",
266   "darwin",
267   "freebsd",
268   "openbsd"
269 ],
270 "cpu": [
271   "x64",
272   "x32",
273   "arm64",
274   "arm"
275 ],
276 "heroku-run-build-script": true,
277 "standard": {
278   "global": [
279     "angular",
280     "inject"
281   ]
282 }
283 }

```

Figure C7 - Public package metadata showing Node.js engine requirements associated with the Juice Shop project. The redacted terminal overlay is unrelated to the dependency evidence.

C.2.4 Express Dependency Metadata

```

juice-shop / package.json
Code Blame 283 lines (283 loc) · 8.26 KB
114 "lcov",
115 "text-summary"
116 ]
117 },
118 "dependencies": {
119   "@fontsource/roboto": "^5.2.9",
120   "body-parser": "^1.20.4",
121   "check-dependencies": "^1.1.1",
122   "check-internet-connected": "^2.0.6",
123   "clarinet": "^0.12.6",
124   "colors": "1.4.0",
125   "compression": "^1.8.1",
126   "config": "^3.3.12",
127   "cookie-parser": "^1.4.7",
128   "cookieconsent": "^3.1.1",
129   "cors": "^2.8.5",
130   "download": "^8.0.0",
131   "errorhandler": "^1.5.1",
132   "ethers": "^6.16.0",
133   "express": "^4.22.1",
134   "express-ipfilter": "^1.3.2",
135   "express-jwt": "0.1.3",
136   "express-rate-limit": "^7.5.1",
137   "express-robots-txt": "^0.5.4",
138   "express-security.txt": "^2.6.0",
139   "feature-policy": "^0.6.0",
140   "file-stream-rotator": "^1.0.0",
141   "file-type": "^16.5.4",
142   "finale-nest": "^1.2.2",
143   "fs-extra": "^9.1.0",

```

Figure C8 - Public package metadata used to identify the Express dependency and support backend framework fingerprinting.

C.2.5 Runtime/Package Metadata Cross-Check

```

juice-shop / package.json
Code Blame 283 lines (283 loc) · 8.26 KB
247   "frisby": "github:bkliminich/frisby",
248   "grunt-cli": "^1.5.0",
249   "jest": "^29.7.0",
250   "mocha": "^8.4.0",
251   "nyc": "^15.1.0",
252   "sinon": "^11.1.2",
253   "sinon-chai": "^3.7.0",
254   "socket.io-client": "^3.1.3",
255   "source-map-support": "^0.5.21",
256   "ts-jest": "^29.2.5",
257   "ts-node": "^10.9.2",
258   "typescript": "^5.3.3",
259
260   "engines": {
261     "node": "20 - 24"
262   },
263   "os": [
264     "win32",
265     "linux",
266     "darwin",
267     "freebsd",
268     "openbsd"
269   ],
270   "cpu": [
271     "x64",
272     "x32",

```

heroku-run-build-script

1 Reference Search

▼ In this file

276 heroku-run-build-script: true,

Search for this symbol

Figure C9 - Additional package metadata used to cross-check runtime and dependency information rather than relying on a single fingerprint source.

C.2.6 SQLite-Related Dependency Metadata

```

juice-shop / ftp / package.json.bak
Code Blame 177 lines (177 loc) · 4.19 KB
60   "jasmine": "^2.8.0",
61   "js-yaml": "3.10",
62   "jsonwebtoken": "~8",
63   "jssha": "~2.3",
64   "libxmljs": "~0.18",
65   "marsdb": "~0.6",
66   "morgan": "~1.9",
67   "multer": "~1.3",
68   "pdfkit": "~0.8",
69   "replace": "~0.3",
70   "request": "~2",
71   "sanitize-html": "1.4.2",
72   "sequelize": "~4",
73   "serve-favicon": "~2.4",
74   "serve-index": "~1.9",
75   "socket.io": "~2.0",
76   "sqlite3": "~3.1.13",
77   "z85": "~0.0"
78 },
79
80 "devDependencies": {
81   "chai": "~4",
82   "codeclimate-test-reporter": "~0.5",
83   "cross-spawn": "~5.1",
84   "eslint": "~4.7",
85   "eslint-scope": "3.7.2",
86   "form-data": "~2.3",
87   "frisby": "~2.0",

```

heroku-run-build-script

1 Reference Search

▼ In this file

276 heroku-run-build-script: true,

Search for this symbol

Figure C10 - Public package metadata identifying SQLite-related components used by the application. This was later distinguished from the application-level SQL injection root cause.

C.3 Known-Vulnerability and Advisory Research

The advisory screenshots document research performed after fingerprinting. They provide patching and technology-risk context only. The report does not claim that every displayed CVE was exploitable in the local lab.

C.3.1 Node.js Security Advisory Context

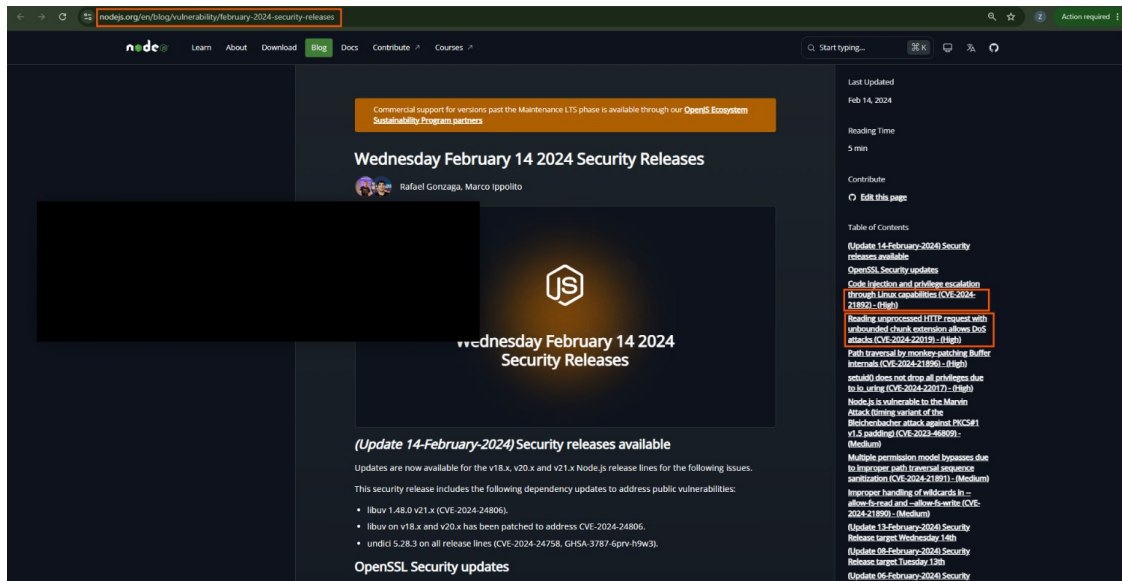


Figure C11 - Node.js security-release research used to establish patching context for the identified runtime.

C.3.2 Express CVE Research - NVD

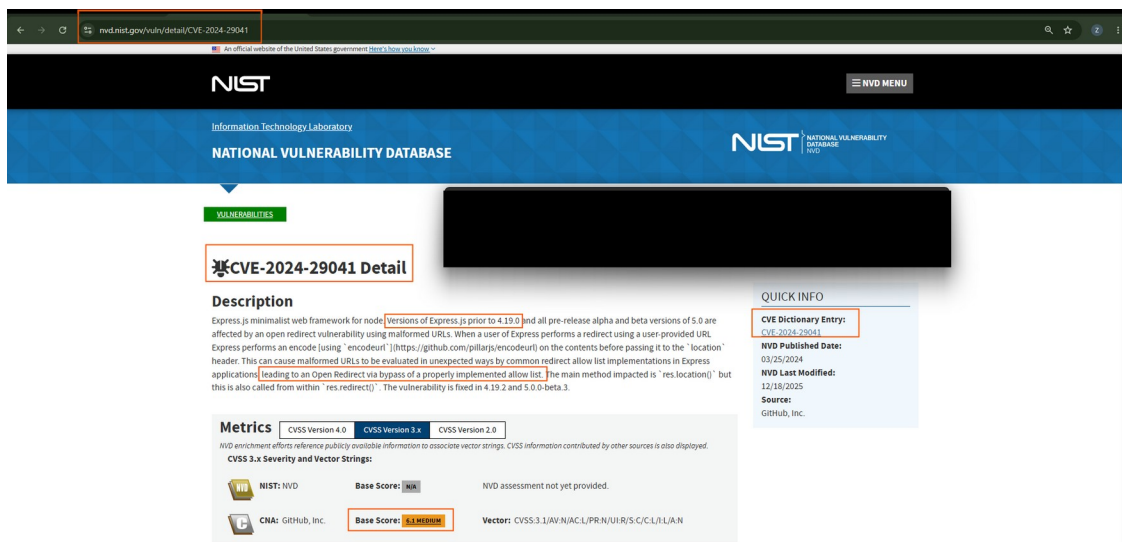


Figure C12 - NVD research for an Express-related CVE. The advisory was reviewed for relevance to the identified backend framework, not treated as proof of a Juice Shop finding.

C.3.3 Express Advisory Cross-Check

The screenshot shows the GitHub Advisory Database page for CVE-2024-43796. The title is "express vulnerable to XSS via response.redirect()". It is marked as "Low severity" and was published on Sep 10, 2024, in the expressjs/express repository, updated on Nov 18, 2024. The package is "express (npm)". Affected versions are "< 4.20.0" and ">= 5.0.0-alpha.1, < 5.0.0". The patched version is "4.20.0" and "5.0.0". The description states that in express < 4.20.0, passing untrusted user input - even after sanitizing it - to response.redirect() may execute untrusted code. Patches are available in express 4.20.0. Workarounds suggest upgrading to the patched version or ensuring untrusted inputs are safe. Details mention that successful exploitation requires the attacker to control the input to response.redirect() and that express must not redirect before the template appears. The CVSS v4 base metrics are: Exploitability Metrics (Attack Vector: Network, Attack Complexity: Low, Attack Requirements: Present, Privileges Required: None, User Interaction: Passive), Vulnerable System Impact Metrics (Confidentiality: None, Integrity: None, Availability: None), and Subsequent System Impact Metrics (Confidentiality: Low, Integrity: Low, Availability: Low). The CVSS v3.1 base metrics are: Attack vector: Network, Attack complexity: Low, Privileges required: None, User interaction: None, Scope: Unchanged, Confidentiality: None, Integrity: None, Availability: High. The EPSS score is 2.246% (85th percentile). Weaknesses include CWE-1333. The CVE ID is CVE-2024-21490.

Figure C13 - Additional Express-related advisory research used to cross-check security impact and affected-package information.

C.3.4 Angular Advisory Research

The screenshot shows the GitHub Advisory Database page for CVE-2024-21490. The title is "angular vulnerable to super-linear runtime due to backtracking". It is marked as "High severity" and was published on Feb 10, 2024, in the angular/angular repository, updated on Nov 4, 2025. The package is "angular (npm)". Affected versions are ">= 1.3.0, <= 1.8.3". The patched version is "None". The description states that this affects versions of the package angular from 1.3.0. A regular expression used to split the value of the ng-srcset directive is vulnerable to super-linear runtime due to backtracking. With a large carefully-crafted input, this can result in catastrophic backtracking and cause a denial of service. A note mentions that this package is EOL and will not receive updates to address this issue. Users should migrate to @angular/core. References include links to NIST CVE details, Security Snyk, BlackBelt, and various security advisories. The CVSS v3 base metrics are: Attack vector: Network, Attack complexity: Low, Privileges required: None, User interaction: None, Scope: Unchanged, Confidentiality: None, Integrity: None, Availability: High. The EPSS score is 2.246% (85th percentile). Weaknesses include CWE-1333. The CVE ID is CVE-2024-21490.

Figure C14 - Angular-related advisory research used to understand client-side framework security considerations.

C.3.5 Additional Angular Advisory Review

GitHub Advisory Database / GitHub Reviewed / CVE-2024-8372

AngularJS allows attackers to bypass common image source restrictions

Low severity | GitHub Reviewed | Published on Sep 9, 2024 to the GitHub Advisory Database • Updated on Nov 4, 2025

Vulnerability details | Dependabot alerts

Package	Affected versions	Patched versions
angular (npm)	>= 1.3.0-rc.4, <= 1.8.3	None

Severity
Low 2.9 / 10

Description

Improper sanitization of the value of the `srcset` attribute in AngularJS allows attackers to bypass common image source restrictions, which can also lead to a form of Content Spoofing https://owasp.org/www-community/attacks/Content_Spoofing.

This issue affects AngularJS versions 1.3.0-rc.4 and greater.

Note:
The AngularJS project is End-of-Life and will not receive any updates to address this issue. For more information see here <https://docs.angularjs.org/misc/version-support-status>.

References

- <https://nvd.nist.gov/vuln/detail/CVE-2024-8372>
- <https://codepen.io/herodevs/full/xxoQRNj/0072e627abe03ef9cda373bc75b4c1017>
- <https://www.herodevs.com/vulnerability-directory/cve-2024-8372>
- <https://security.netapp.com/advisory/ntap-20241122-0002>
- <https://lists.debian.org/debian-lts-announce/2025/07/msg00005.html>

CVSS v4 base metrics

Exploitability Metrics	Network
Attack Vector	Low
Attack Complexity	Present
Attack Requirements	None
Privileges Required	None
User Interaction	None
Vulnerable System Impact Metrics	
Confidentiality	Low
Integrity	Low
Availability	None
Subsequent System Impact Metrics	
Confidentiality	None
Integrity	None
Availability	None

[Learn more about base metrics](#)

CVSS:4.0/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Figure C15 - Additional Angular advisory research used as patching context for the client-side framework.

C.3.6 SQLite CVE Research - NVD

NIST
Information Technology Laboratory
NATIONAL VULNERABILITY DATABASE

VULNERABILITIES

CVE-2024-0232 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

A heap use-after-free issue has been identified in SQLite in the `jsonParseAddNodeArray()` function in `sqlite3.c`. This flaw allows a local attacker to leverage a victim to pass specially crafted malicious input to the application, potentially causing a crash and leading to a denial of service.

Metrics

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

Source	Base Score	Vector
NIST: NVD	5.5 MEDIUM	CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
CNA: Red Hat, Inc.	5.7 MEDIUM	CVSS:3.1/AV:L/AC:H/PR:N/UI:R/S:U/C:N/I:N/A:H

QUICK INFO

CVE Dictionary Entry:
CVE-2024-0232

NVD Published Date:
01/16/2024

NVD Last Modified:
11/21/2024

Source:
Red Hat, Inc.

Figure C16 - NVD research for a SQLite-related vulnerability. The later SQL injection finding is explicitly treated as application-level query construction, not as this CVE.

C.3.7 Additional SQLite CVE Research

The screenshot displays the NIST National Vulnerability Database (NVD) page for CVE-2023-7104. The page is titled "NIST NATIONAL VULNERABILITY DATABASE" and includes a "VULNERABILITIES" tab. The main content area shows the "CVE-2023-7104 Detail" section, which includes a "Description" and "Metrics" for CVSS 3.1, NIST, and CNA. The description states: "A vulnerability was found in SQLite up to 3.43.0 and classified as critical. This issue affects the function sessionReadRecord of the file ext/session/sqlite3session.c of the component make alltest Handler. The manipulation leads to heap-based buffer overflow. It is recommended to apply a patch to fix this issue. The associated identifier of this vulnerability is VDB-248999." The metrics section shows the CVSS 3.1 score as 9.8 (CRITICAL), the NIST score as 9.8 (CRITICAL), and the CNA score as 9.8 (CRITICAL). A large black redaction box covers the top right portion of the page.

Figure C17 - Additional SQLite-related CVE research used to understand dependency risk and patching requirements.

C.4 Scanning, Enumeration, and Attack-Surface Discovery

These screenshots show the transition from passive research to direct testing of the authorized local target. They document the open service, exposed routes, public files, and client-side route discovery that informed vulnerability selection.

C.4.1 Local Port and Service Scan

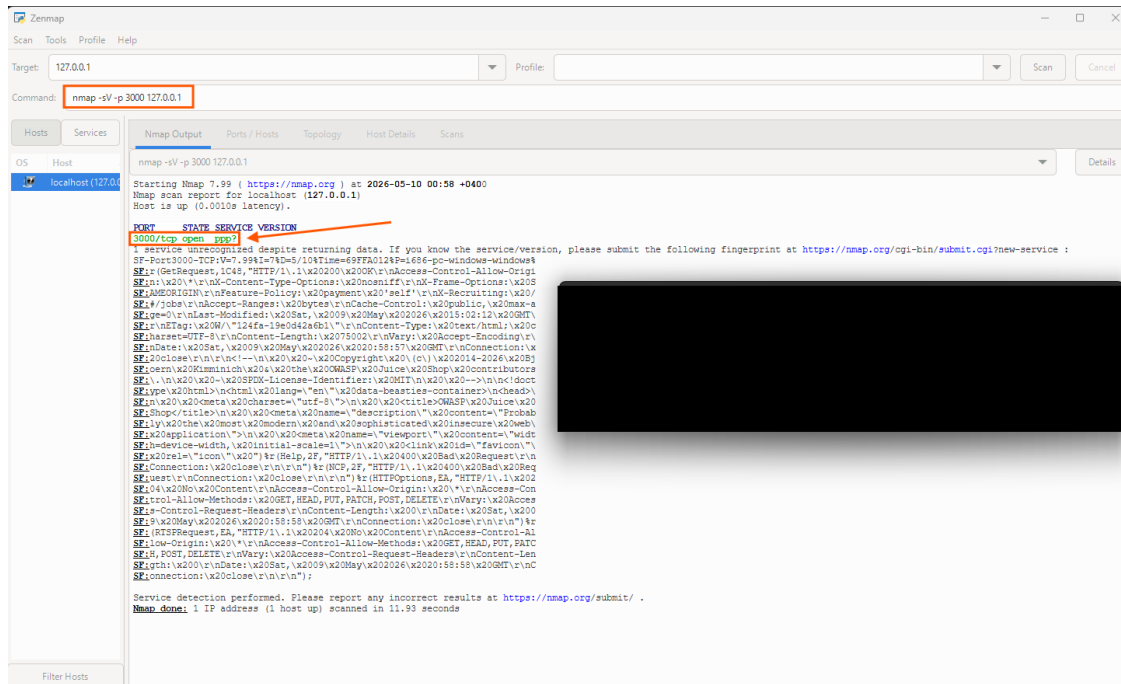


Figure C18 - Original redacted Nmap/Zenmap evidence confirming the local HTTP service on TCP port 3000. The cleaner crop appears in the main report.

C.4.2 HTTP and Browser Inspection

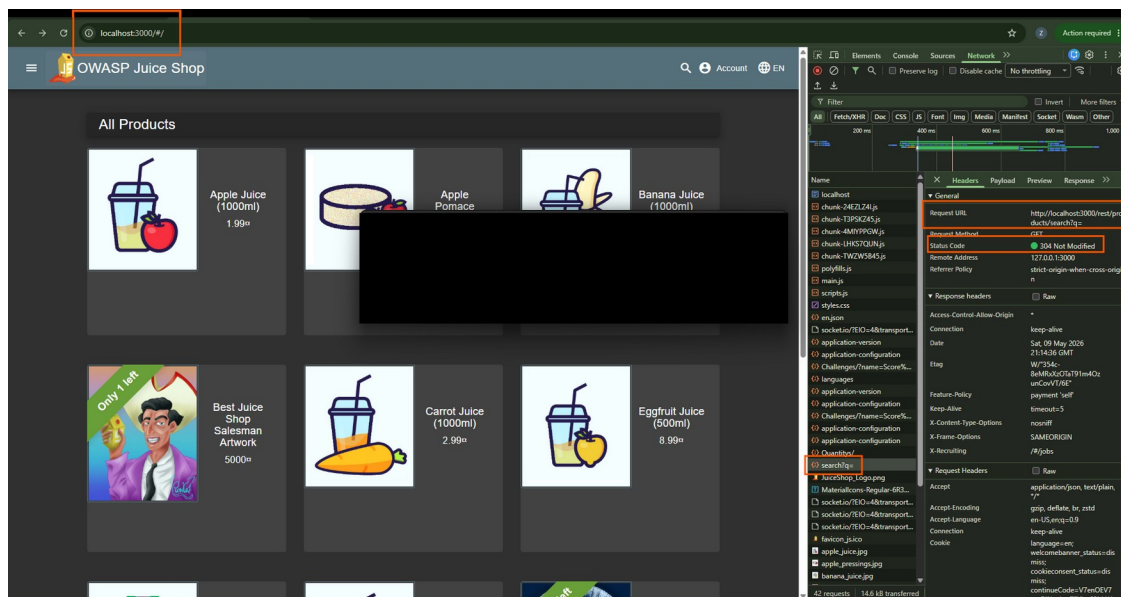


Figure C19 - Browser and response-header inspection used to identify security-relevant headers and framework disclosure.

C.4.3 REST/API Enumeration

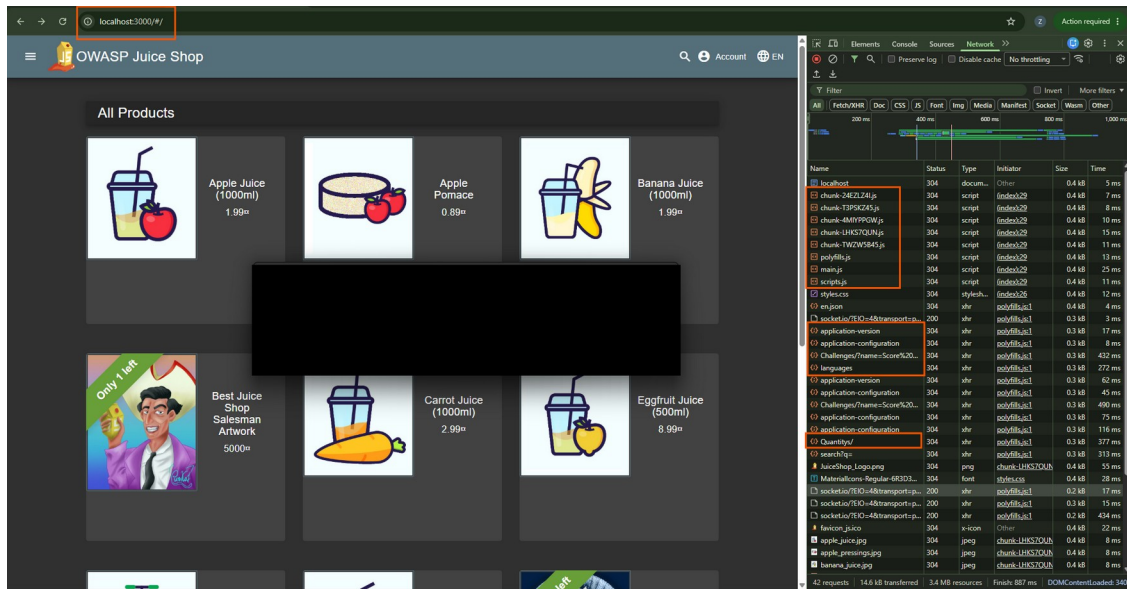


Figure C20 - Browser Network-panel evidence showing REST/API calls generated by the Angular frontend. This exposed routes later used for login, metrics, and other validation.

C.4.4 Public File Directory Discovery

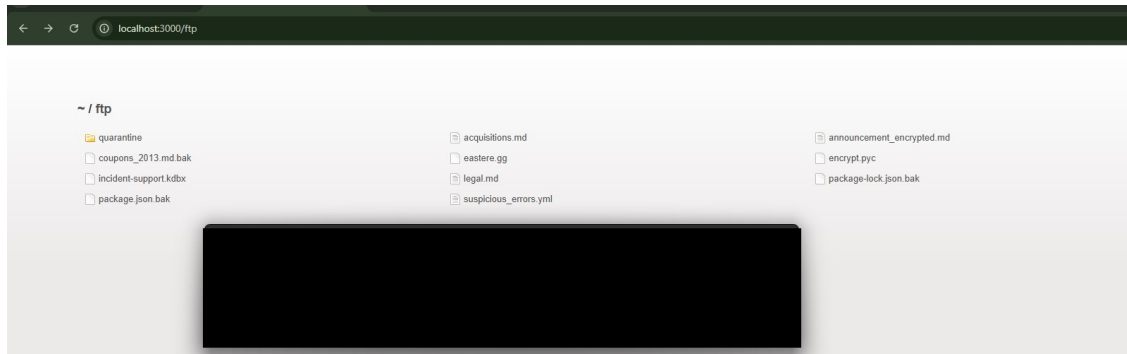


Figure C21 - Original evidence of the publicly reachable /ftp directory. The unrelated terminal content is fully redacted.

C.4.5 Client-Side Source Review

Figure C22 - Client-side JavaScript/source review used to locate hidden route references. This demonstrates why frontend route hiding is not a server-side access control.

C.4.6 Vulnerability Candidate Review

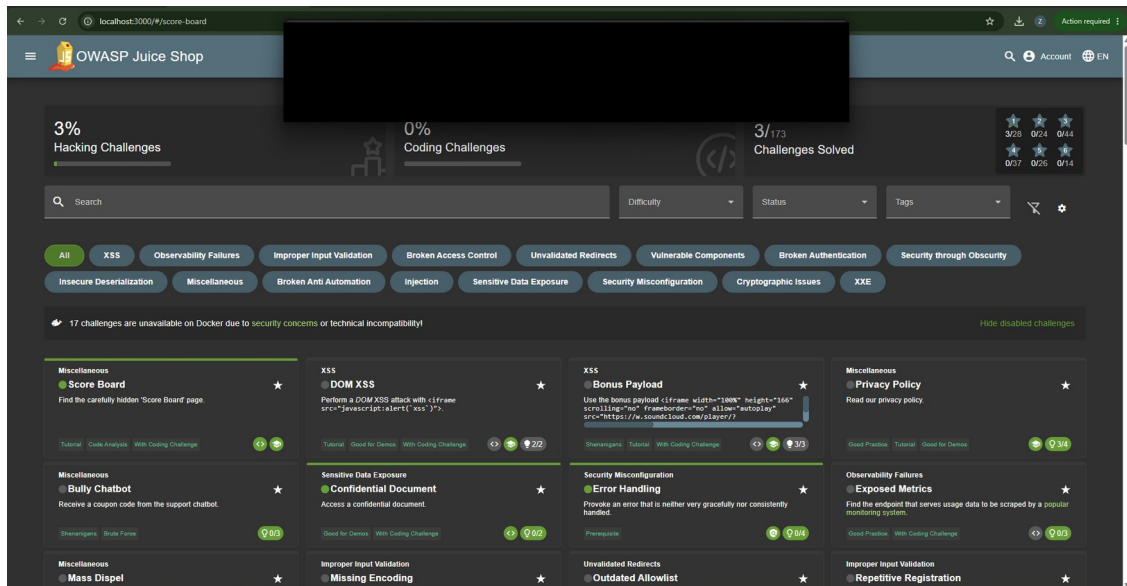


Figure C23 - Juice Shop challenge/scoreboard state used while selecting candidate vulnerabilities for manual validation and prioritization.

C.4.7 Hidden Scoreboard Route Validation

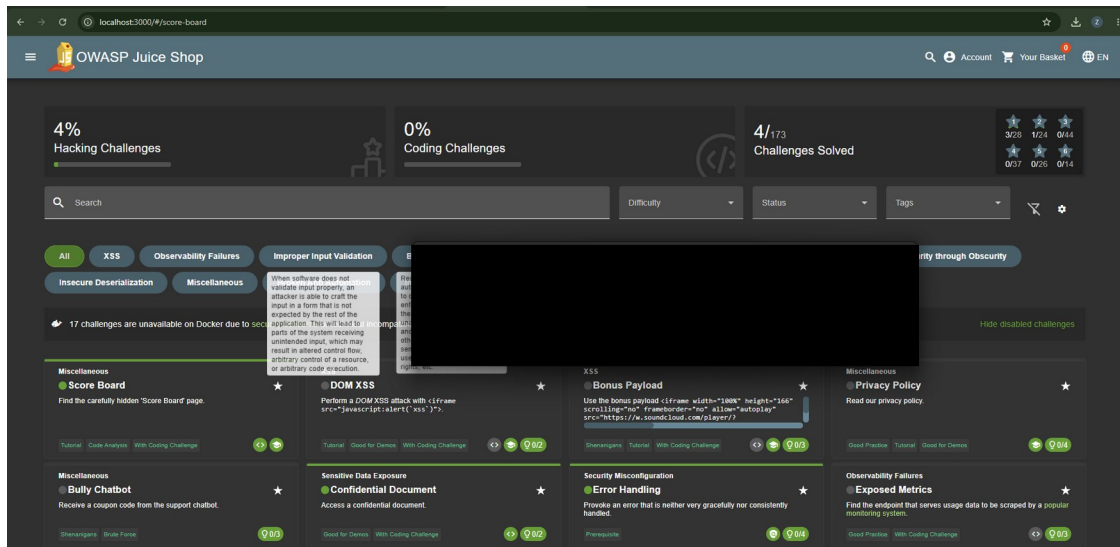


Figure C24 - Direct validation of the hidden scoreboard route after discovering its reference in client-side application assets.

C.5 Exploitation and Finding Validation

This evidence set documents the controlled proof-of-concept phase. The images show the input or request used, the application behavior that followed, and the resulting access or exposed data.

C.5.1 SQL Injection Input

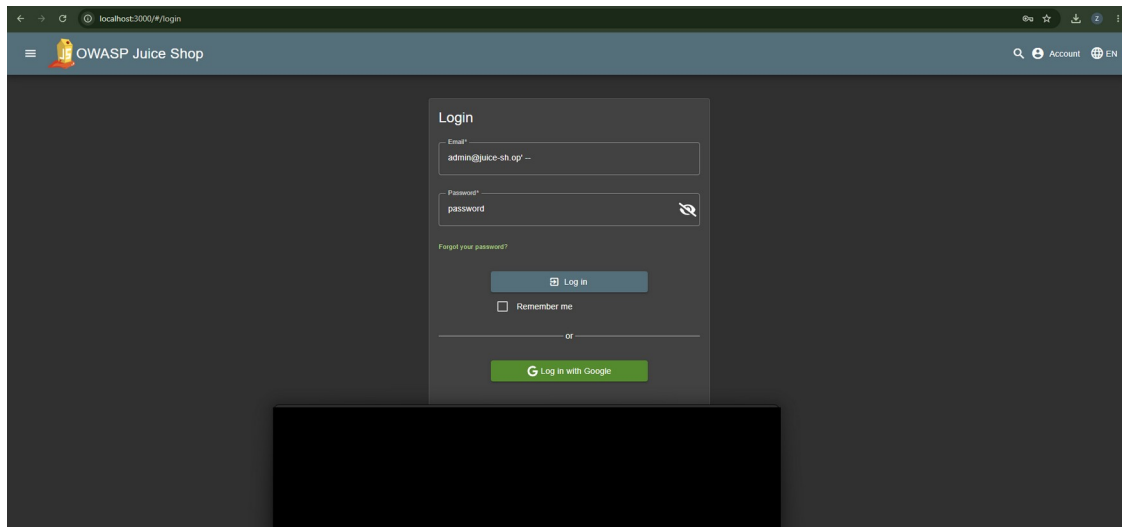


Figure C25 - Login form evidence showing the SQL-injection test input used to alter authentication query logic. The session-identification overlay is redacted.

C.5.2 SQL Injection Result

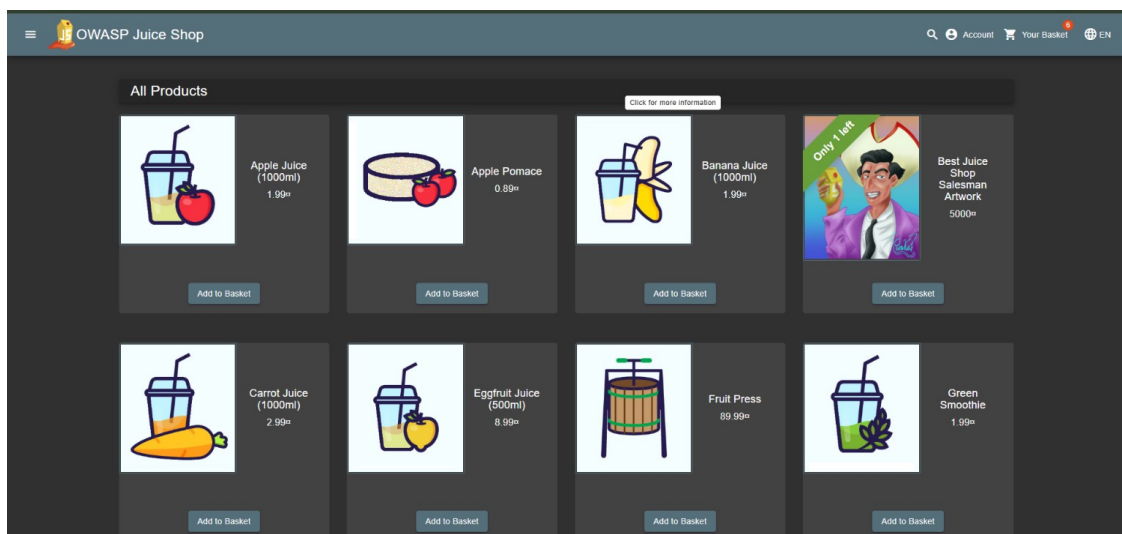


Figure C26 - Application state following the injected login, demonstrating that the authentication-bypass test produced privileged access.

C.5.3 DOM-Based XSS Validation

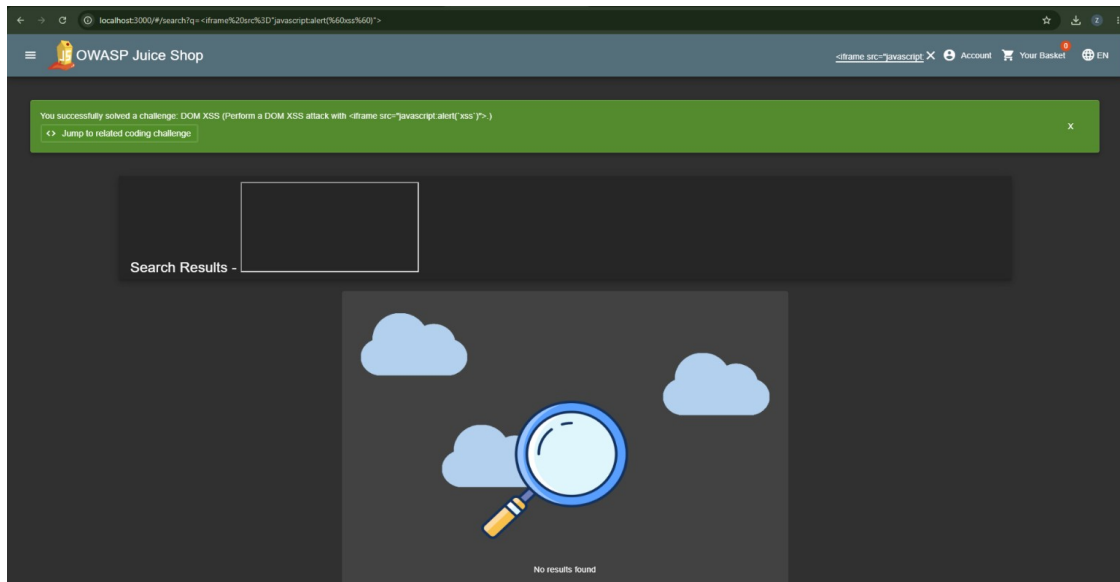


Figure C27 - Search-interface evidence showing successful execution of the DOM-based XSS test payload.

C.5.4 Extended XSS Payload Validation

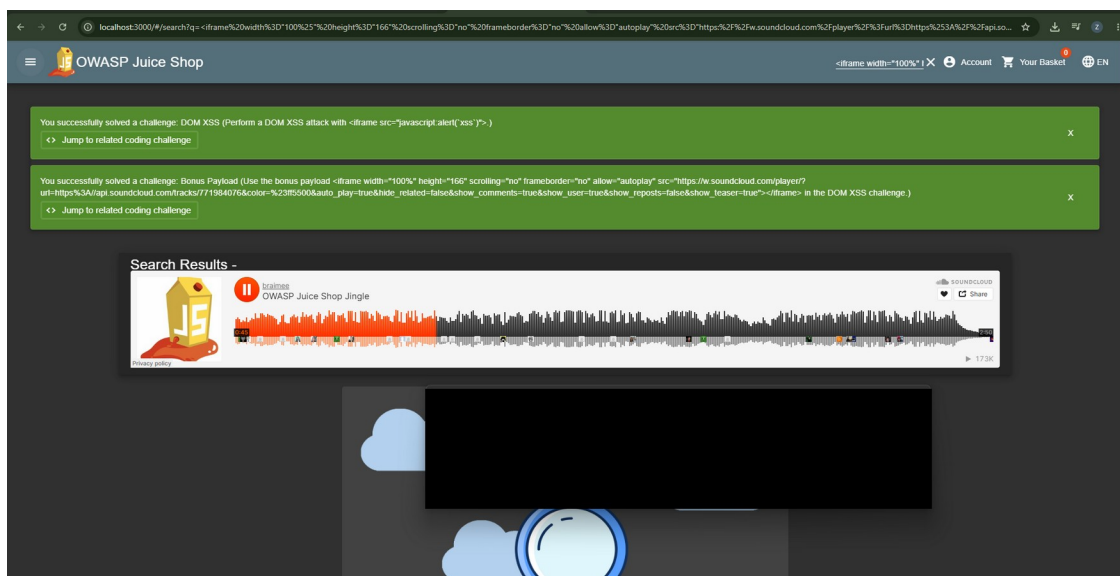


Figure C28 - Extended XSS payload rendered through the same unsafe DOM injection path, demonstrating that the sink could embed richer attacker-controlled content.

C.5.5 Exposed Metrics Endpoint

```

# HELP file_uploads_count Total number of successful file uploads grouped by file type.
# TYPE file_uploads_count counter
# HELP file_upload_errors Total number of failed file uploads grouped by file type.
# TYPE file_upload_errors counter
# HELP juiceshop_startup_duration_seconds Duration juiceshop required to perform a certain task during startup
# TYPE juiceshop_startup_duration_seconds gauge
juiceshop_startup_duration_seconds{task="validateConfig",app="juiceshop"} 0.041539562
juiceshop_startup_duration_seconds{task="cleanupStatic",app="juiceshop"} 0.47282572
juiceshop_startup_duration_seconds{task="validatePrerequisites",app="juiceshop"} 0.277261839
juiceshop_startup_duration_seconds{task="datacreator",app="juiceshop"} 22.85524893
juiceshop_startup_duration_seconds{task="customizeApplication",app="juiceshop"} 0.019736629
juiceshop_startup_duration_seconds{task="customizeSettings",app="juiceshop"} 0.00779245
juiceshop_startup_duration_seconds{task="ready",app="juiceshop"} 22.959
# HELP process_cpu_user_seconds_total Total user CPU time spent in seconds.
# TYPE process_cpu_user_seconds_total counter
process_cpu_user_seconds_total{app="juiceshop"} 34.259957
# HELP process_cpu_system_seconds_total Total system CPU time spent in seconds.
# TYPE process_cpu_system_seconds_total counter
process_cpu_system_seconds_total{app="juiceshop"} 11.568824
# HELP process_cpu_seconds_total Total user and system CPU time spent in seconds.
# TYPE process_cpu_seconds_total counter
process_cpu_seconds_total{app="juiceshop"} 46.82781
# HELP process_start_time_seconds Start time of the process since unix epoch in seconds.
# TYPE process_start_time_seconds gauge
process_start_time_seconds{app="juiceshop"} 1778405777
# HELP process_resident_memory_bytes Resident memory size in bytes.
# TYPE process_resident_memory_bytes gauge
process_resident_memory_bytes{app="juiceshop"} 186224648
# HELP process_virtual_memory_bytes Virtual memory size in bytes.
# TYPE process_virtual_memory_bytes gauge
process_virtual_memory_bytes{app="juiceshop"} 1833828160
# HELP process_heap_bytes Process heap size in bytes.
# TYPE process_heap_bytes gauge
process_heap_bytes{app="juiceshop"} 781218272
# HELP process_open_fds Number of open file descriptors.
# TYPE process_open_fds gauge
process_open_fds{app="juiceshop"} 28
# HELP process_max_fds Maximum number of open file descriptors.
# TYPE process_max_fds gauge
process_max_fds{app="juiceshop"} 1048576
# HELP nodejs_eventloop_lag_seconds Lag of event loop in seconds.
# TYPE nodejs_eventloop_lag_seconds gauge
nodejs_eventloop_lag_seconds{app="juiceshop"} 0
# HELP nodejs_eventloop_lag_min_seconds The minimum recorded event loop delay.
# TYPE nodejs_eventloop_lag_min_seconds gauge
nodejs_eventloop_lag_min_seconds{app="juiceshop"} 0.00136192
# HELP nodejs_eventloop_lag_max_seconds The maximum recorded event loop delay.
# TYPE nodejs_eventloop_lag_max_seconds gauge
nodejs_eventloop_lag_max_seconds{app="juiceshop"} 0

```

Figure C29 - Direct access to the metrics endpoint showing runtime/monitoring information without authentication.

C.5.6 Confidential Document Retrieval

```

# Planned Acquisitions
> This document is confidential! Do not distribute!

Our company plans to acquire several competitors within the next year.
This will have a significant stock market impact as we will elaborate in
detail in the following paragraph:

Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy
eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam
voluptus. At vero eos et accusam et justo duo dolores et ea rebum. Stet
clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit
amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam
nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat,
sed diam voluptus. At vero eos et accusam et justo duo dolores et ea
rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem
ipsum dolor sit amet.

Our shareholders will be excited. It's true. No fake news.

```

Figure C30 - Confidential-document content retrieved from the exposed file path. The unrelated session overlay is redacted.

C.5.7 Confidential-File Validation State

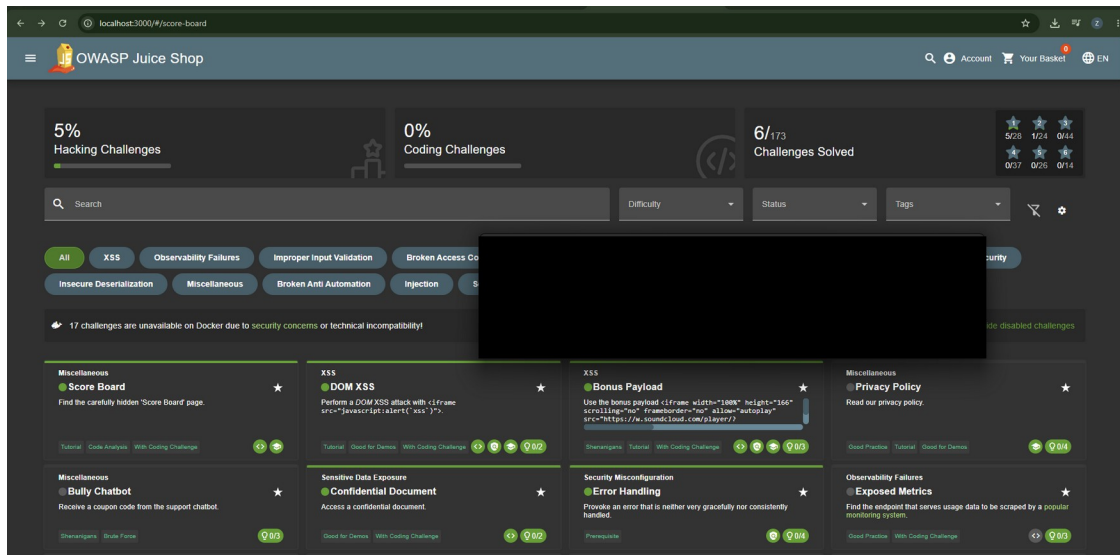


Figure C31 - Application validation state associated with the confidential-document exposure, preserved as supporting evidence.

C.5.8 Verbose Error Response



Figure C32 - Detailed Express error page returned by an unexpected route, exposing stack-trace and internal application information.

C.5.9 Administrative Access

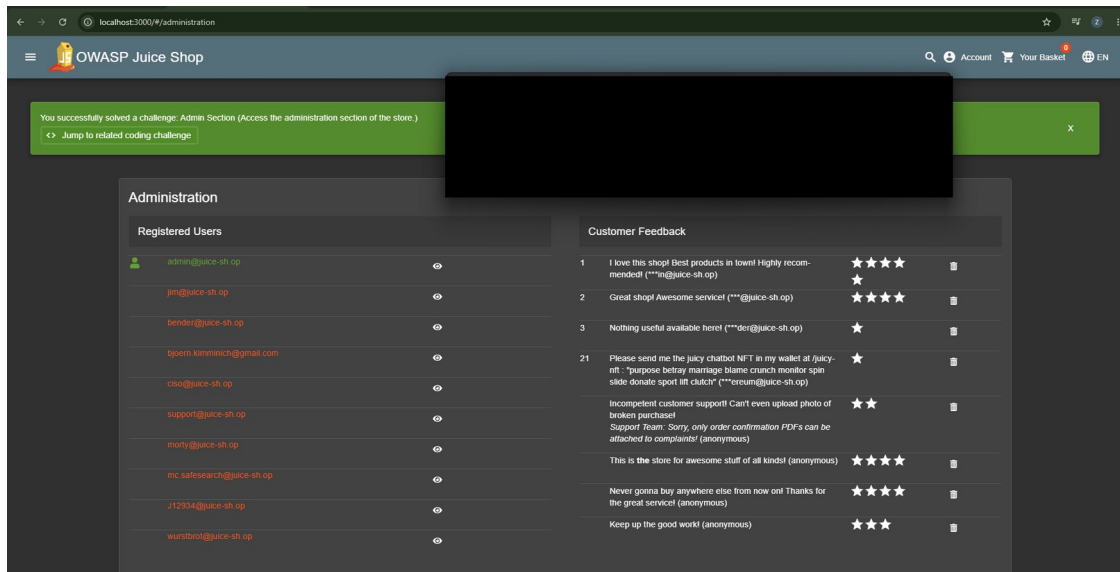


Figure C33 - Administrative interface reached after the authentication-bypass sequence. Personal/session metadata is covered while application functionality remains visible.

C.5.10 Backup-File Challenge State

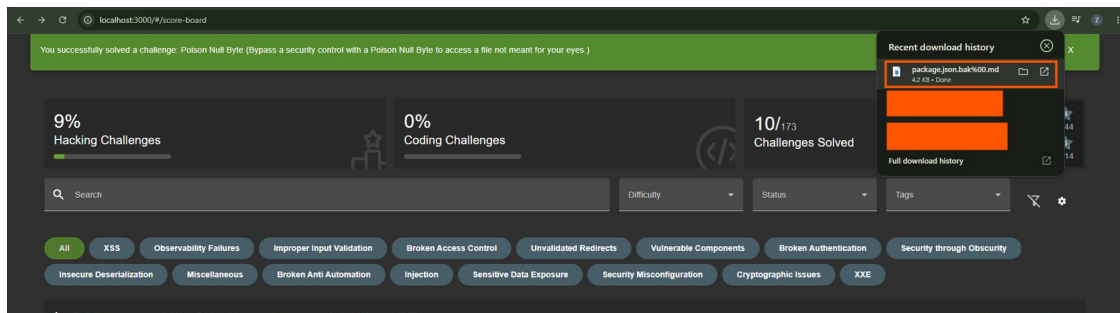
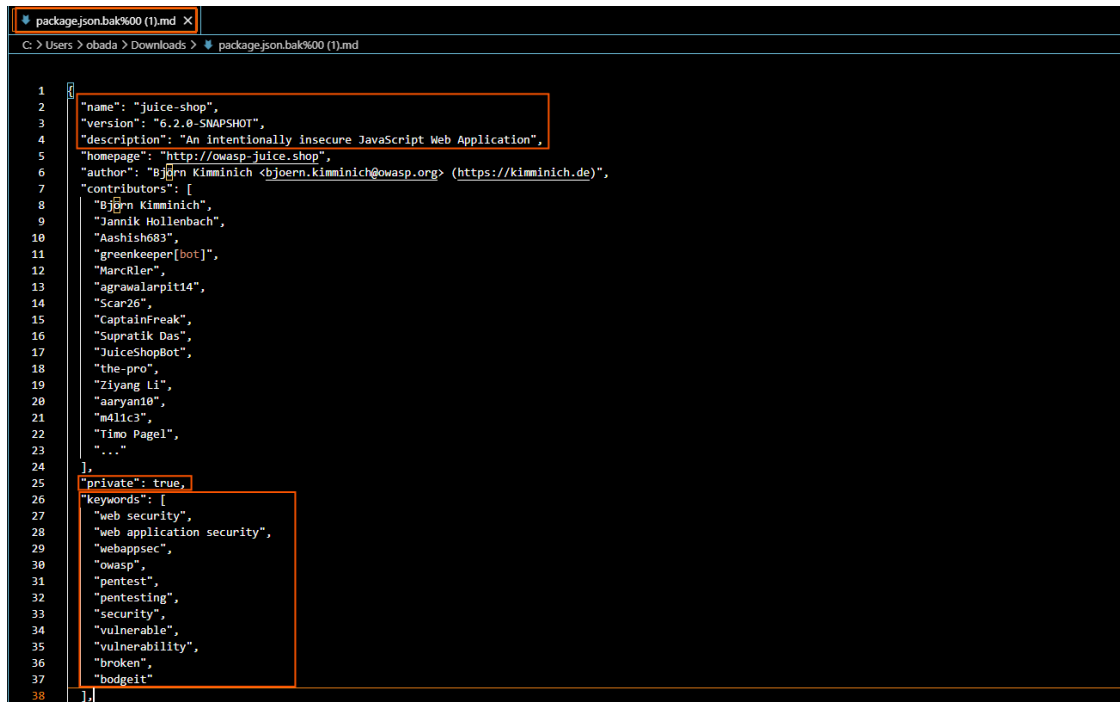


Figure C34 - Juice Shop state associated with backup-file retrieval and advanced validation.

C.5.11 Retrieved Backup Package Metadata



The screenshot shows a code editor with a file named 'package.json.bak%00 (1).md'. The file content is a JSON object representing package metadata. The following fields are highlighted with orange boxes:

- `"name": "juice-shop",`
- `"version": "6.2.0-SNAPSHOT",`
- `"description": "An intentionally insecure JavaScript Web Application",`
- `"homepage": "http://owasp-juice.shop",`
- `"author": "Björn Kimminich <bjoern.kimminich@owasp.org> (https://kimminich.de)",`
- `"private": true,`
- `"keywords": [`
- `"web security",`
- `"web application security",`
- `"webappsec",`
- `"owasp",`
- `"pentest",`
- `"pentesting",`
- `"security",`
- `"vulnerable",`
- `"vulnerability",`
- `"broken",`
- `"bodgeit"`

```
1  {
2    "name": "juice-shop",
3    "version": "6.2.0-SNAPSHOT",
4    "description": "An intentionally insecure JavaScript Web Application",
5    "homepage": "http://owasp-juice.shop",
6    "author": "Björn Kimminich <bjoern.kimminich@owasp.org> (https://kimminich.de)",
7    "contributors": [
8      "Björn Kimminich",
9      "Jannik Hollenbach",
10     "Aashish683",
11     "greenkeeper[bot]",
12     "MarcRler",
13     "agrawalarpit14",
14     "Scar26",
15     "CaptainFreak",
16     "Supratik Das",
17     "JuiceShopBot",
18     "the-pro",
19     "Ziyang Li",
20     "aaryan10",
21     "m4ll1c3",
22     "Timo Pagel",
23     "...",
24   ],
25   "private": true,
26   "keywords": [
27     "web security",
28     "web application security",
29     "webappsec",
30     "owasp",
31     "pentest",
32     "pentesting",
33     "security",
34     "vulnerable",
35     "vulnerability",
36     "broken",
37     "bodgeit"
38 ]
```

Figure C35 - Package metadata exposed after the encoded null-byte file-access bypass, demonstrating why backup artifacts provide useful dependency intelligence.

C.6 Post-Exploitation State and Detection Evidence

The final evidence set documents impact and defender visibility. It shows exposed application state after validation and the container/application logs that would help a defender reconstruct suspicious activity.

C.6.1 Public File Exposure - Post-Validation



Figure C36 - Additional view of the public file directory retained as post-validation evidence of the information-disclosure path.

C.6.2 Privileged Application State

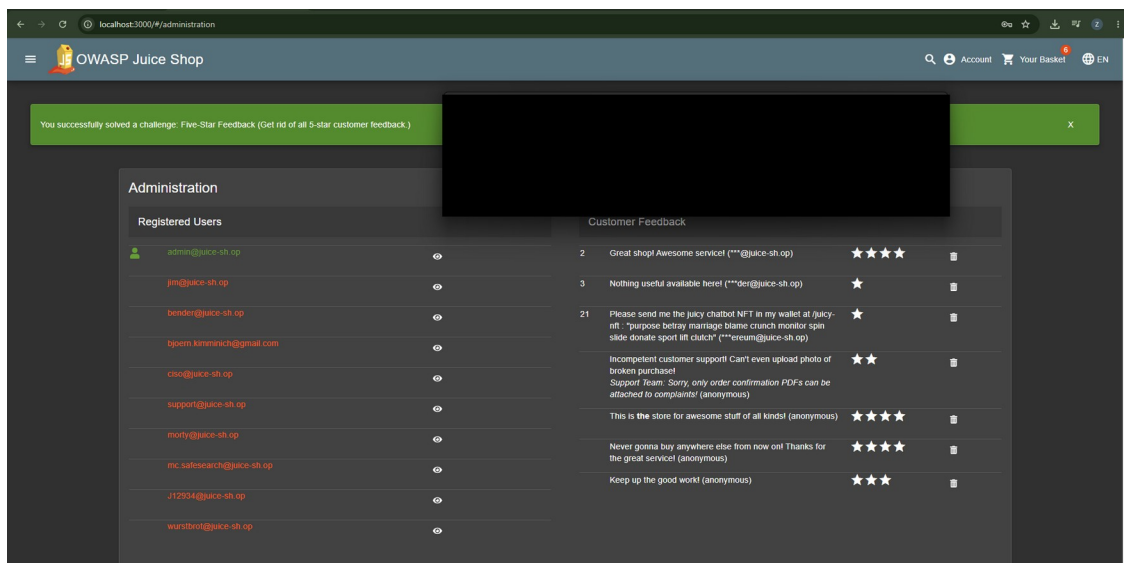


Figure C37 - Additional administrative-interface evidence showing privileged application state after the validated attack chain.

C.6.3 Docker/Application Logs - Part 1

```

C:\WINDOWS\system32\cmd. X + v
echo DateTime: %date%
DateTime: 10/05/2026

docker logs -tail 80
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:196:5)
Error: Only .md and .pdf files are allowed!
at verify (/juice-shop/build/routes/fileServer.js:59:18)
at /juice-shop/build/routes/fileServer.js:43:13
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at param (/juice-shop/node_modules/express/lib/router/index.js:365:14)
at param (/juice-shop/node_modules/express/lib/router/index.js:376:14)
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:196:5)
Error: Only .md and .pdf files are allowed!
at verify (/juice-shop/build/routes/fileServer.js:59:18)
at /juice-shop/build/routes/fileServer.js:43:13
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at param (/juice-shop/node_modules/express/lib/router/index.js:365:14)
at param (/juice-shop/node_modules/express/lib/router/index.js:376:14)
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:196:5)
info: Solved 2-star loginAdminChallenge (Login Admin)
info: Cheat score for tutorial loginAdminChallenge solved in 20min (expected ~2min) with hints allowed: 0
info: Solved 1-star localXssChallenge (DOM XSS)
info: Cheat score for tutorial localXssChallenge solved in 18min (expected ~1min) with hints allowed: 0
info: Solved 1-star xssBonusChallenge (Bonus Payload)
info: Cheat score for tutorial xssBonusChallenge solved in 2min (expected ~1min) with hints allowed: 0
info: Solved 1-star exposedMetricsChallenge (Exposed Metrics)
info: Cheat score for exposedMetricsChallenge solved in 7min (expected ~2min) with hints allowed: 0
Error: Unexpected path: /rest/qwertz
at /juice-shop/build/routes/angular.js:42:18
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/build/routes/verify.js:288:5

```

Figure C38 - Container/application log output showing errors and challenge-related events generated during testing. This evidence supports detection and incident-reconstruction analysis.

C.6.4 Docker/Application Logs - Part 2

```

C:\WINDOWS\system32\cmd. X + v
info: Cheat score for tutorial loginAdminChallenge solved in 20min (expected ~2min) with hints allowed: 0
info: Solved 1-star localXssChallenge (DOM XSS)
info: Cheat score for tutorial localXssChallenge solved in 18min (expected ~1min) with hints allowed: 0
info: Solved 1-star xssBonusChallenge (Bonus Payload)
info: Cheat score for tutorial xssBonusChallenge solved in 2min (expected ~1min) with hints allowed: 0
info: Solved 1-star exposedMetricsChallenge (Exposed Metrics)
info: Cheat score for exposedMetricsChallenge solved in 7min (expected ~2min) with hints allowed: 0
Error: Unexpected path: /rest/qwertz
at /juice-shop/build/routes/angular.js:42:18
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/build/routes/verify.js:288:5
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/build/routes/verify.js:111:5
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/build/routes/verify.js:111:5
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
info: Solved 2-star adminSectionChallenge (Admin Section)
info: Cheat score for tutorial adminSectionChallenge solved in 16min (expected ~2min) with hints allowed: 0
info: Solved 4-star forgottenDevBackupChallenge (Forgotten Developer Backup)
info: Cheat score for forgottenDevBackupChallenge solved in 2min (expected ~8min) with hints allowed and 100% expected preceding URL interaction: 0.7942833333333333
info: Solved 4-star nullByteChallenge (Poison Null Byte)
info: Cheat score for coupled nullByteChallenge solved in 0min (expected ~0min) with hints allowed: 0
info: Solved 1-star privacyPolicyChallenge (Privacy Policy)
info: Cheat score for trivial tutorial privacyPolicyChallenge solved in 7min (expected ~0min) with hints allowed: 0
info: Solved 2-star feedbackChallenge (Five-Star Feedback)
info: Cheat score for feedbackChallenge solved in 2min (expected ~4min) with hints allowed: 0.3792208333333333
info: Solved 5-star extraLanguageChallenge (Extra Language)
info: Cheat score for extraLanguageChallenge solved in 8min (expected ~10min) with hints allowed: 0.1531066666666666
info: Solved 5-star retrieveBlueprintChallenge (Retrieve Blueprint)
info: Cheat score for retrieveBlueprintChallenge solved in 9min (expected ~10min) with hints allowed: 0.09384499999999999
Error
at Database.<anonymous> (/juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:185:27)
at /juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:183:50
at new Promise (<anonymous>)
at Query.run (/juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:183:12)
at /juice-shop/node_modules/sequelize/lib/sequelize.js:315:28
at process.processTicksAndRejections (node:internal/process/task_queues:104:5)

```

Figure C39 - Continuation of the Docker/application log evidence, preserving additional server-side events generated by the assessment.

C.6.5 Additional Challenge-State Evidence

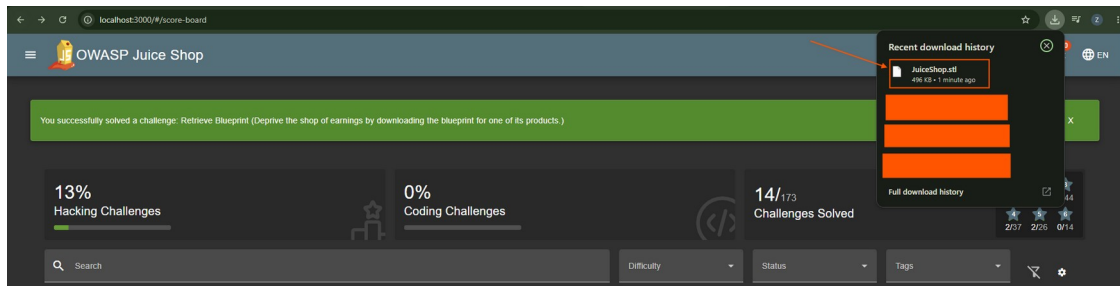


Figure C40 - Additional scoreboard/challenge-state evidence collected after validation steps.

C.6.6 Additional Application-State Evidence

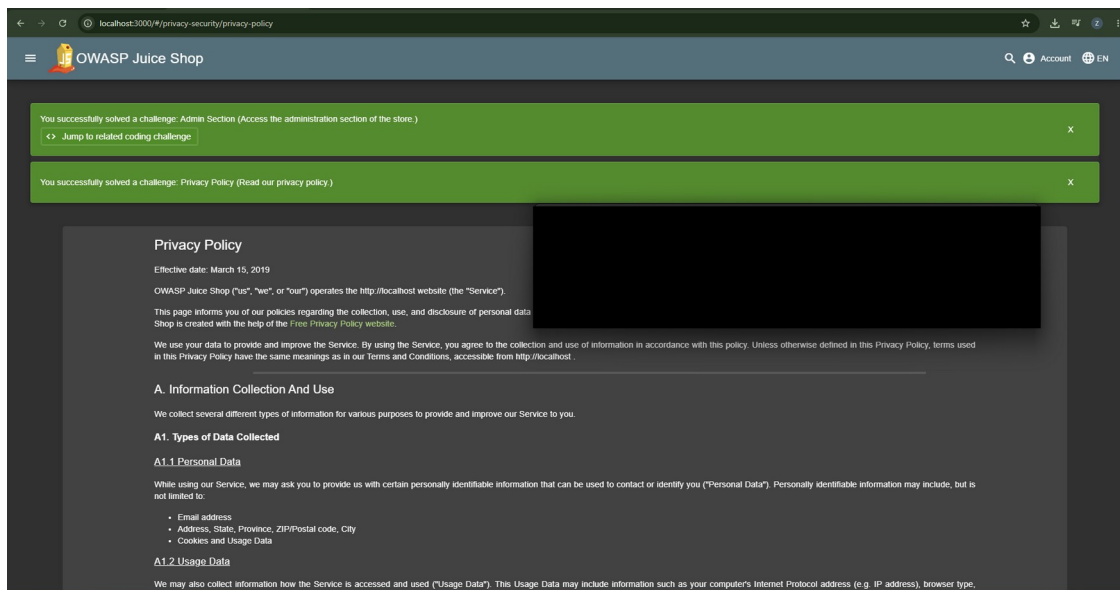


Figure C41 - Additional Juice Shop application-state evidence. The original personal/session terminal area has been fully covered with a black privacy box.

C.6.7 Hidden-Page Validation Evidence

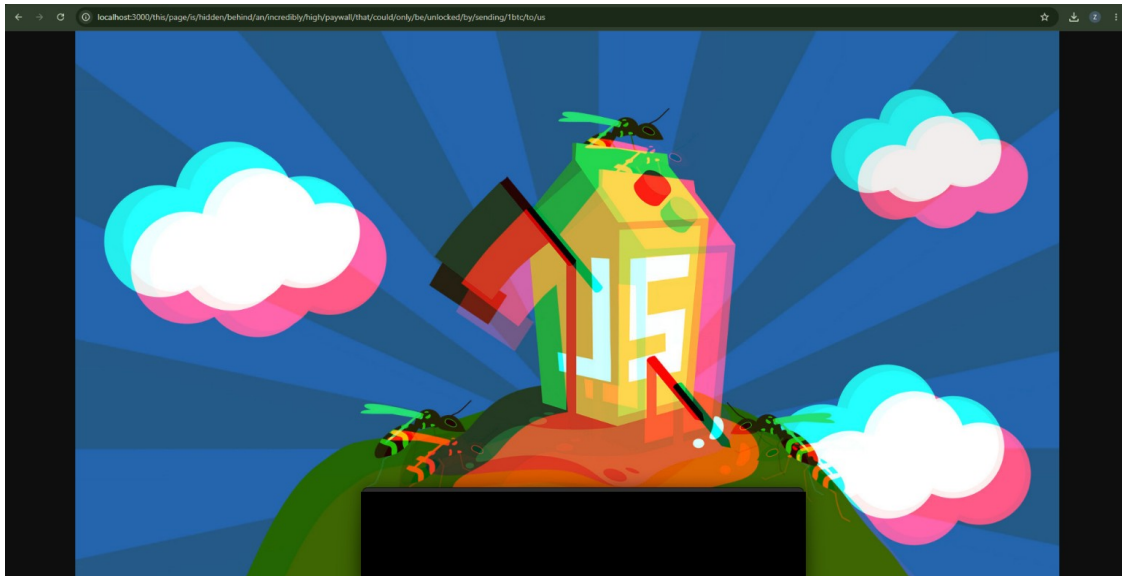


Figure C42 - Additional hidden-page validation evidence with the original personal/session metadata fully redacted.

Appendix D. References

- OWASP Foundation - OWASP Juice Shop Project - <https://owasp.org/www-project-juice-shop/>
- OWASP Juice Shop Companion Guide - <https://pwning.owasp-juice.shop/>
- OWASP Top 10 (2021) - <https://owasp.org/Top10/>
- Docker Hub - bkimminich/juice-shop - <https://hub.docker.com/r/bkimminich/juice-shop/>
- NIST National Vulnerability Database (NVD) - <https://nvd.nist.gov/>
- MITRE CVE - <https://cve.mitre.org/>
- GitHub Security Advisories - <https://github.com/advisories>
- OWASP Cross Site Scripting Prevention Cheat Sheet - https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
- OWASP SQL Injection Prevention Cheat Sheet - https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
- CWE-284: Improper Access Control - <https://cwe.mitre.org/data/definitions/284.html>
- CWE-538: File and Directory Information Exposure - <https://cwe.mitre.org/data/definitions/538.html>

End of Report